



ZÁKLADY KYBERNETICKÉ BEZPEČNOSTI II.

Ing. Miroslav Bureš

Obsah

- Základní principy počítačových sítí
- Útoky na počítačovou síť a bezpečnost síťových zařízení
- Logování a analýza provozu
- Identity management
- Kryptografie a digitální certifikáty
- Šifrování a tunelování provozu v počítačové síti
- IPS a IDS systémy
- Firewall

ZÁKLADNÍ PRINCIPY POČÍTAČOVÝCH SÍTÍ

Typy počítačových sítí

- SOHO (Small Office/Home Office)
- Enterprise
- BAN (Body Area Network)
- PAN (Personal Area Network)
- LAN (Local Area Network)
- MAN (Metropolitan Area Network)
- WAN (Wide Area Network)

Síťové zařízení

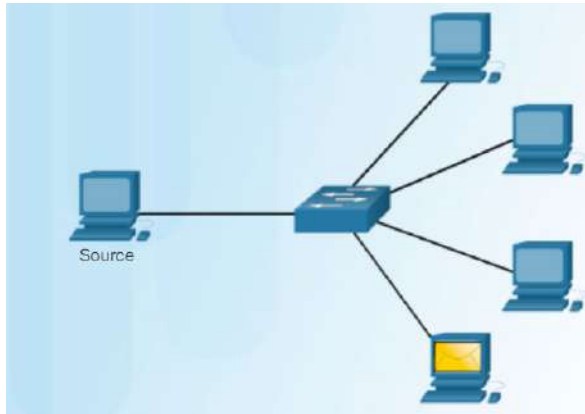
- Přepínač - L2/L3
- Směrovač
- WLC + AP/AP
- Firewall
- Server – IdM, DHCP, DNS, FS, CA, RADIUS, ...
- VPN koncentrátor
- IPS/IDS
- Collaboration, Data Center

Kabeláž v počítačových sítích

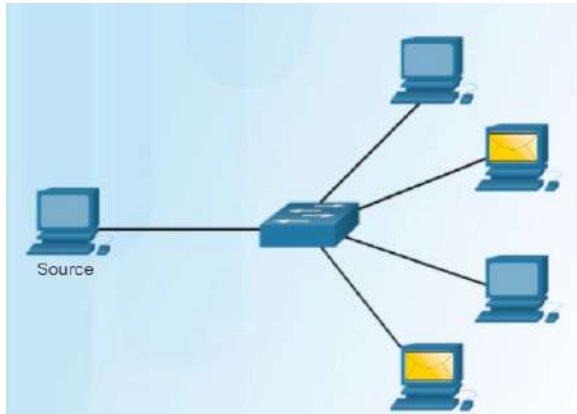
- Metallické kabely
 - UTP/STP min. Cat. 6, lépe Cat. 6A - horizontální rozvody
- Optické kabely
 - multimodové optické kabely s min. 4 vlákny – horizontální rozvody
 - singlemódové optické kabely s min. 16 vlákny – vertikální rozvody

Unicast, Multicast, Broadcast

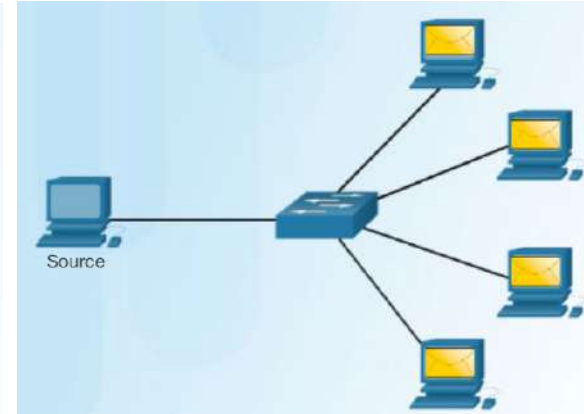
Unicast – one-to-one



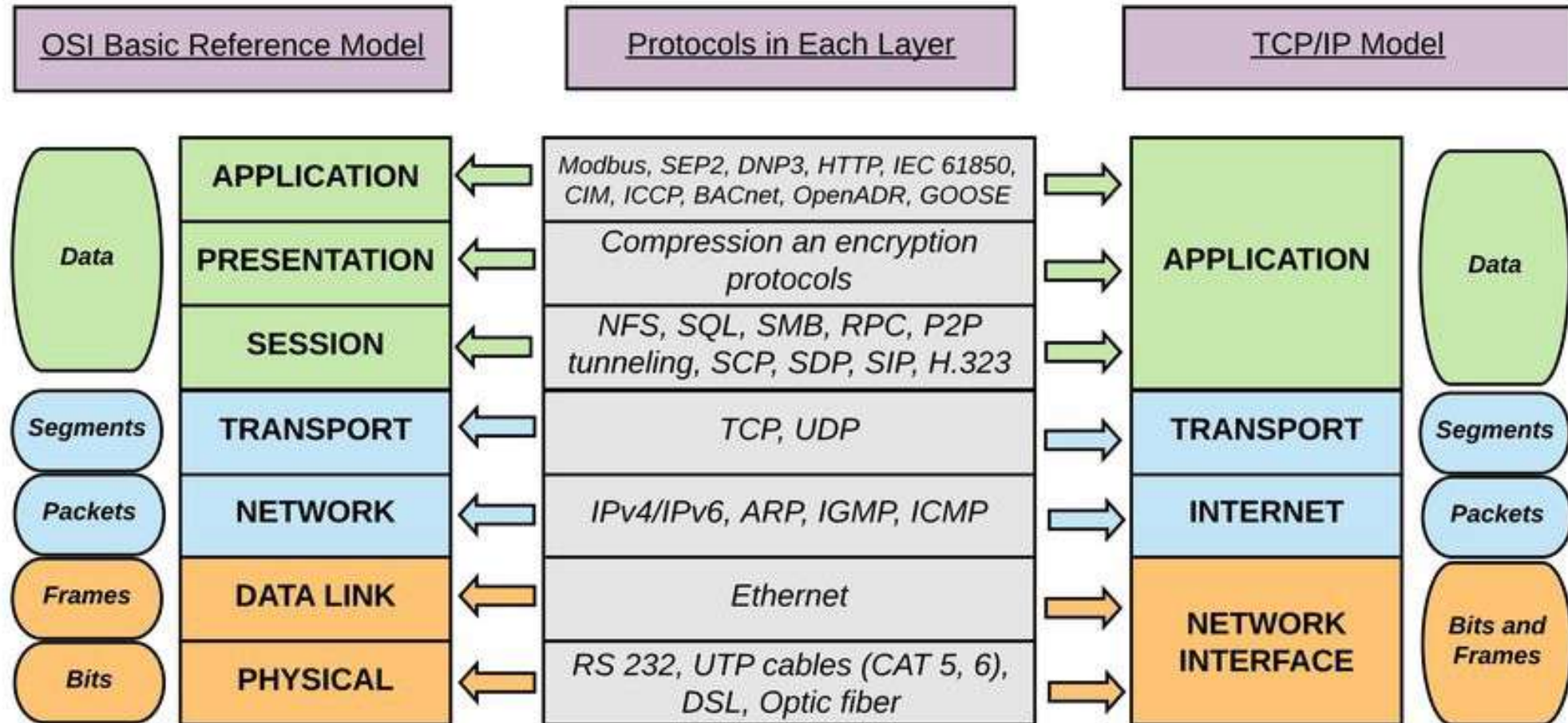
Multicast – one-to-many



Broadcast – one-to-all



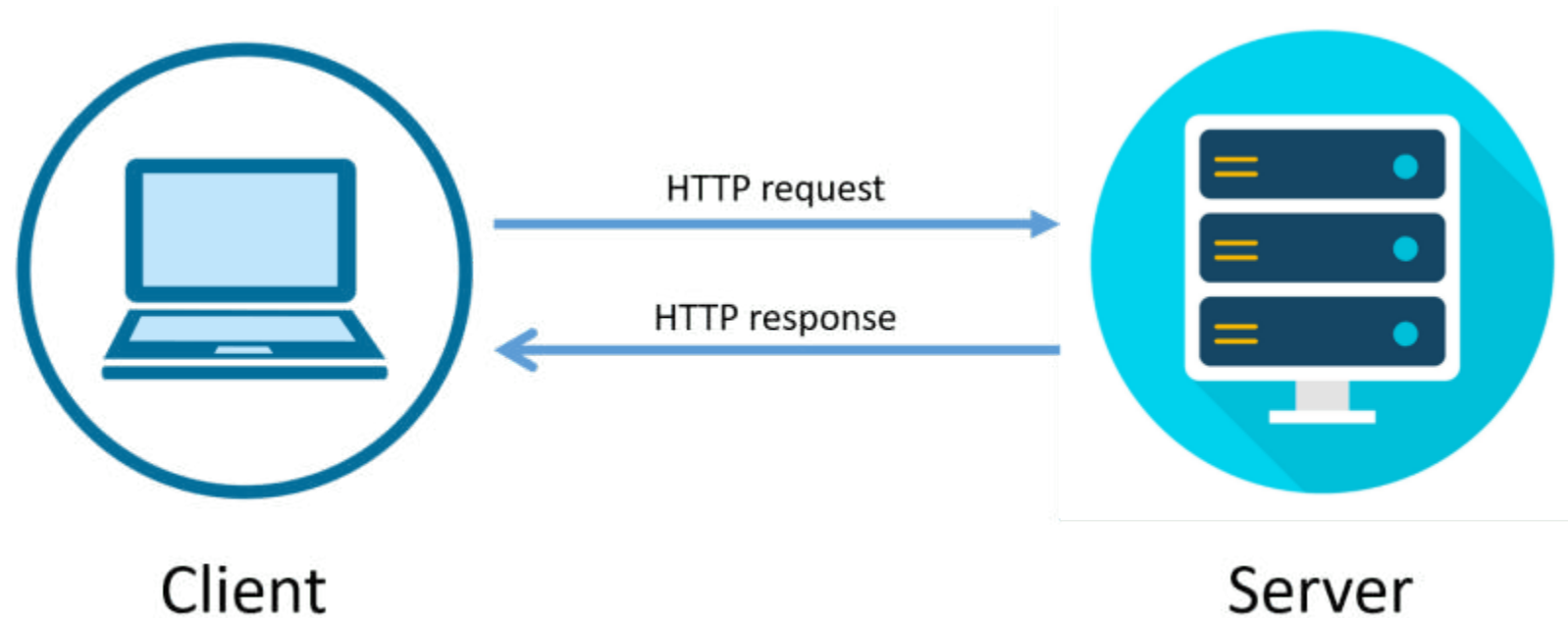
ISO/OSI a TCP/IP model



Aplikační protokoly

- HTTP a HTTPS
- DNS
- DHCP
- SMTP, IMAP, POP

Hypertext Transfer Protocol/Secure (HTTP/S)



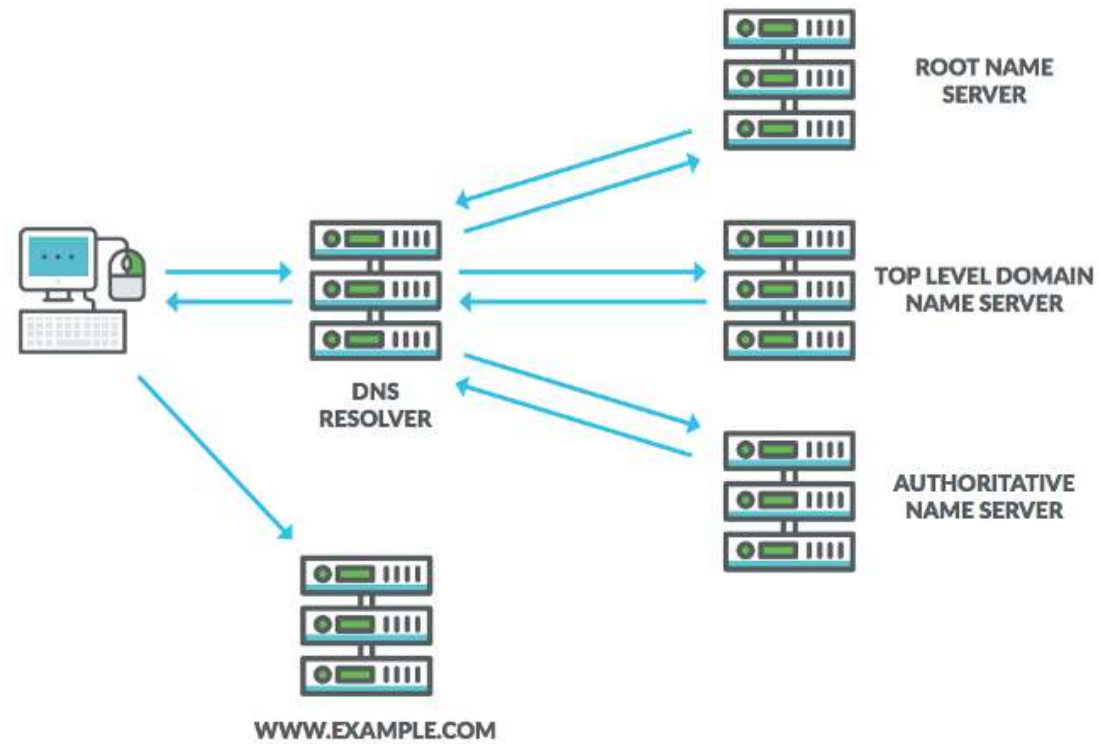
HTTP metody

- **GET** - požadavek na uvedený objekt se zasláním případných dat (proměnné prohlížeče, session id, ...). Výchozí metoda při požadavku na zobrazení hypertextových stránek, RSS feedů aj. Celkově nejpoužívanější.
- **HEAD** - metoda podobná GET, avšak nepředává data. Poskytne pouze metadata o požadovaném cíli (velikost, typ, datum změny, ...).
- **POST** - odesílá uživatelská data na server. Používá se například při odesílání formuláře na webu. S předaným objektem se pak zachází podobně jako při metodě GET. Data může odesílat i metoda GET, metoda POST se však používá pro příliš velký objem dat (více než 512 bajtů, což je velikost požadavku GET), nebo pokud není vhodné přenášet data zobrazit jako součást URL (data předávaná metodou POST jsou obsažena v HTTP požadavku).
- **PUT** – nahraje data na server. Objekt je jméno vytvářeného souboru. Používá se velmi zřídka, pro nahrávání dat na server se běžně používá FTP nebo SCP/SSH.
- **DELETE** - smaže uvedený objekt ze serveru. K tomu je zapotřebí jistých oprávnění stejně jako u metody PUT.
- **TRACE** - odešle kopii obdrženého požadavku zpět odesílateli, takže klient může zjistit, co na požadavku mění nebo přidávají servery, kterými požadavek prochází.
- **OPTIONS** - dotaz na server, jaké podporuje metody.
- **CONNECT** - spojí se s uvedeným objektem přes uvedený port. Používá se při průchodu skrze proxy pro ustanovení kanálu SSL.

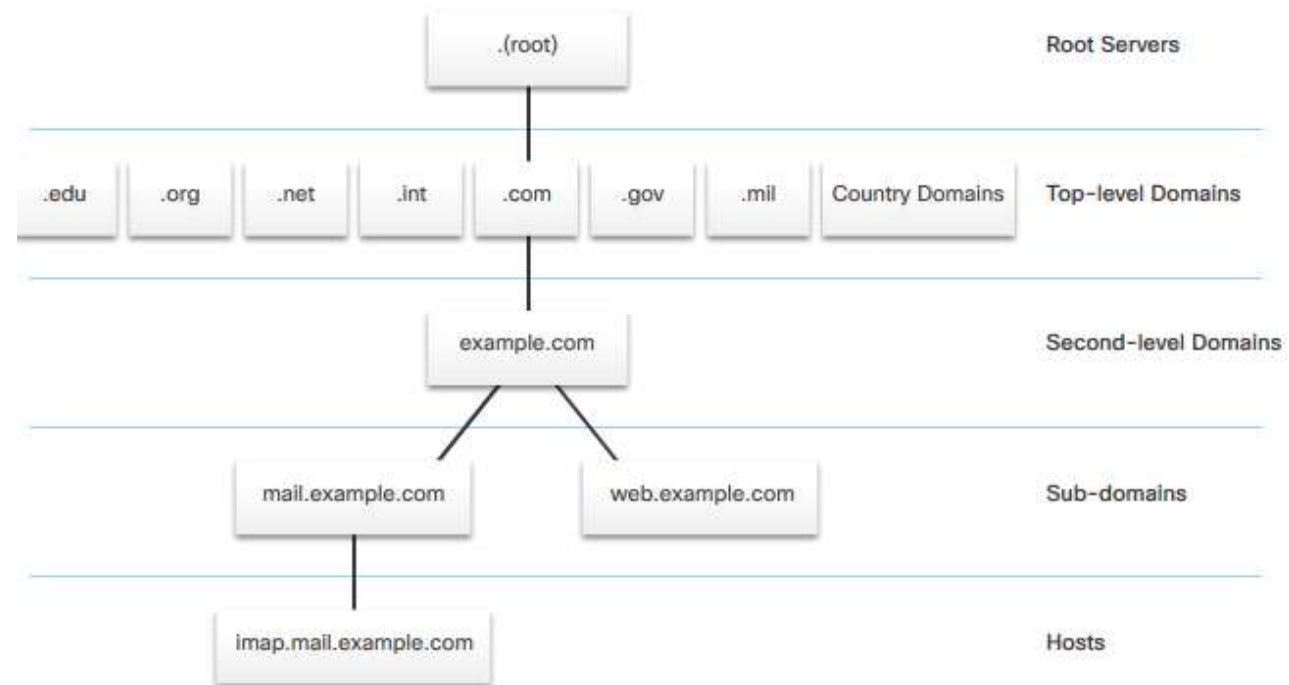
HTTP odpovědi

- 1xx Informační
- 2xx Success
- 3xx Redirect
- 4xx Client Error
- 5xx Server Error

Domain Name System (DNS)



DNS Domain Hierarchy



Top-Level Domains - TLDs

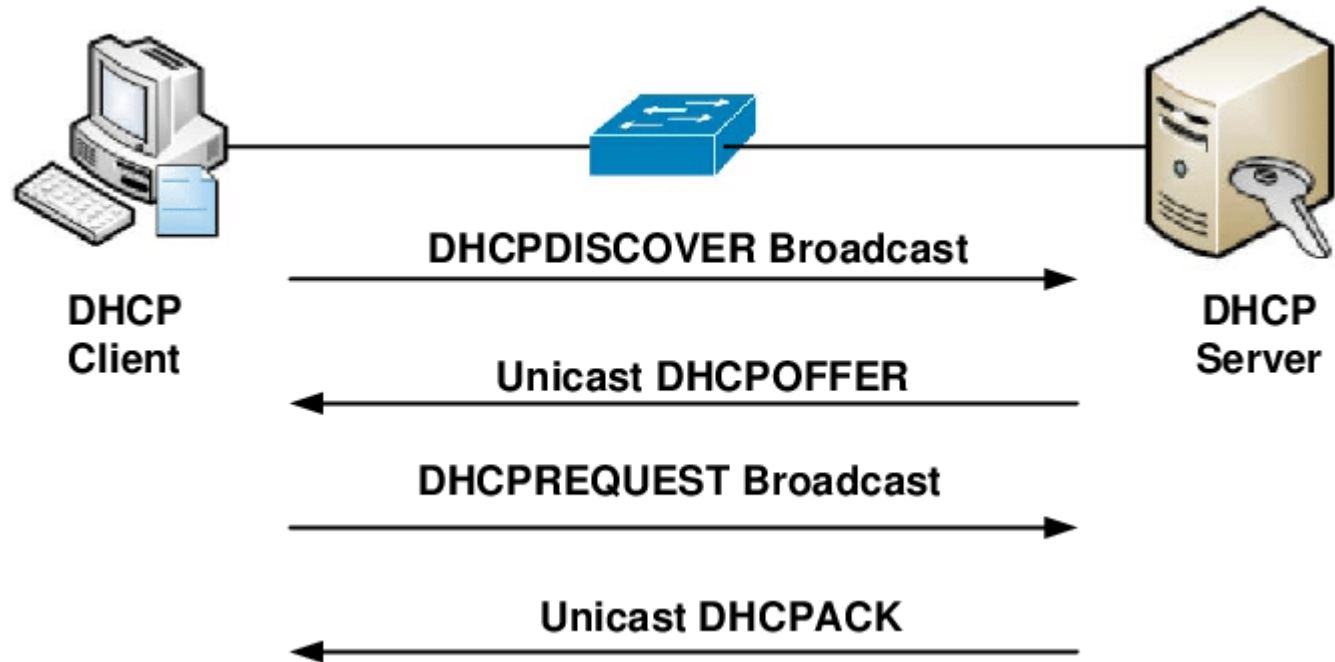
- **gTLD** - generic top-level domains - .com, .net, .gov, .org, ...
- **ccTLD** - country code top-level domains - .ca, .uk, .ae, .fr, .cz, ...
- **sTLD** - sponsored top-level domains: .museum, .travel, .sch, ...

List of Top-Level Domains

<https://data.iana.org/TLD/tlds-alpha-by-domain.txt>

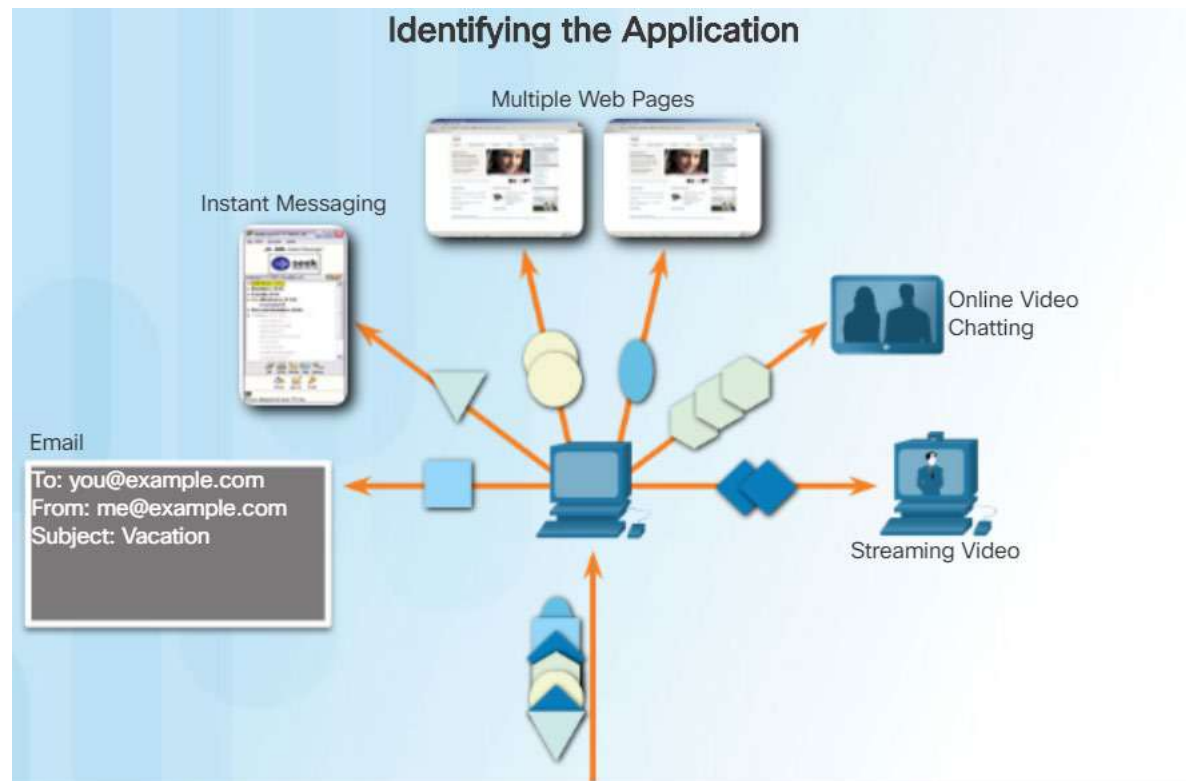
Dynamic Host Configuration Protocol (DHCP)

- DHCP client
- DHCP server
- DHCP relay

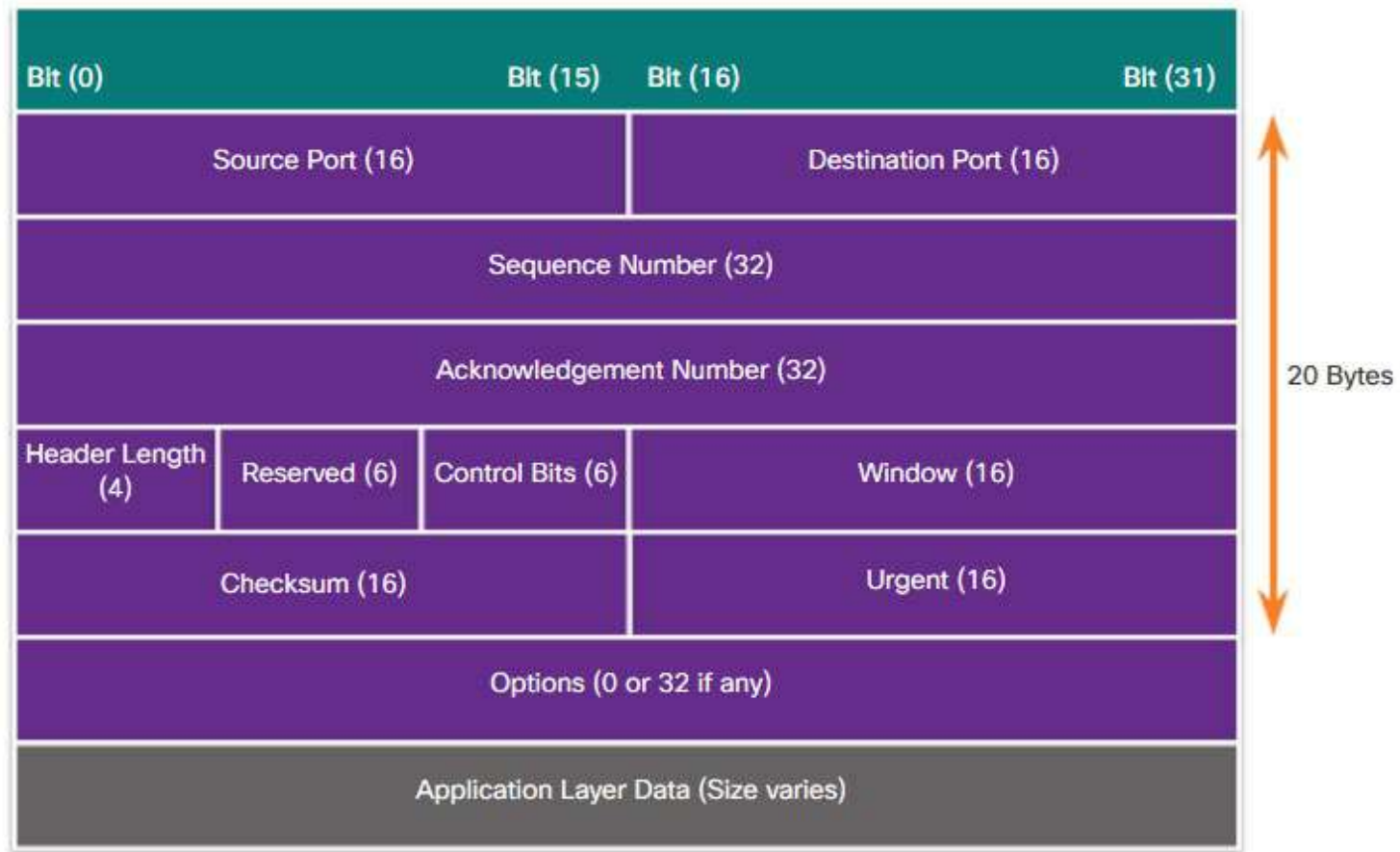


Transportní protokoly

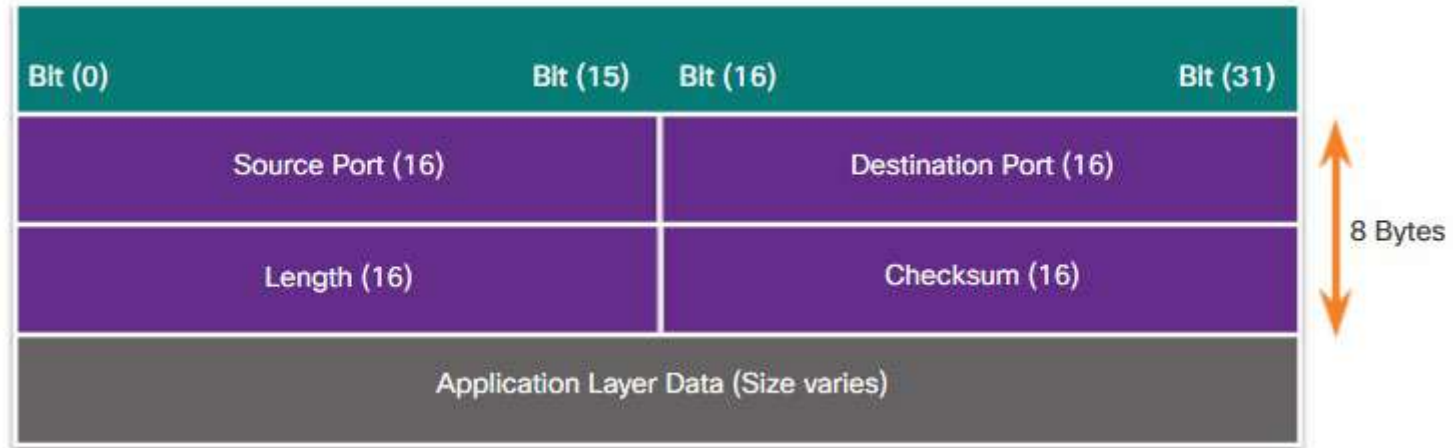
- TCP
- UDP



TCP Segment



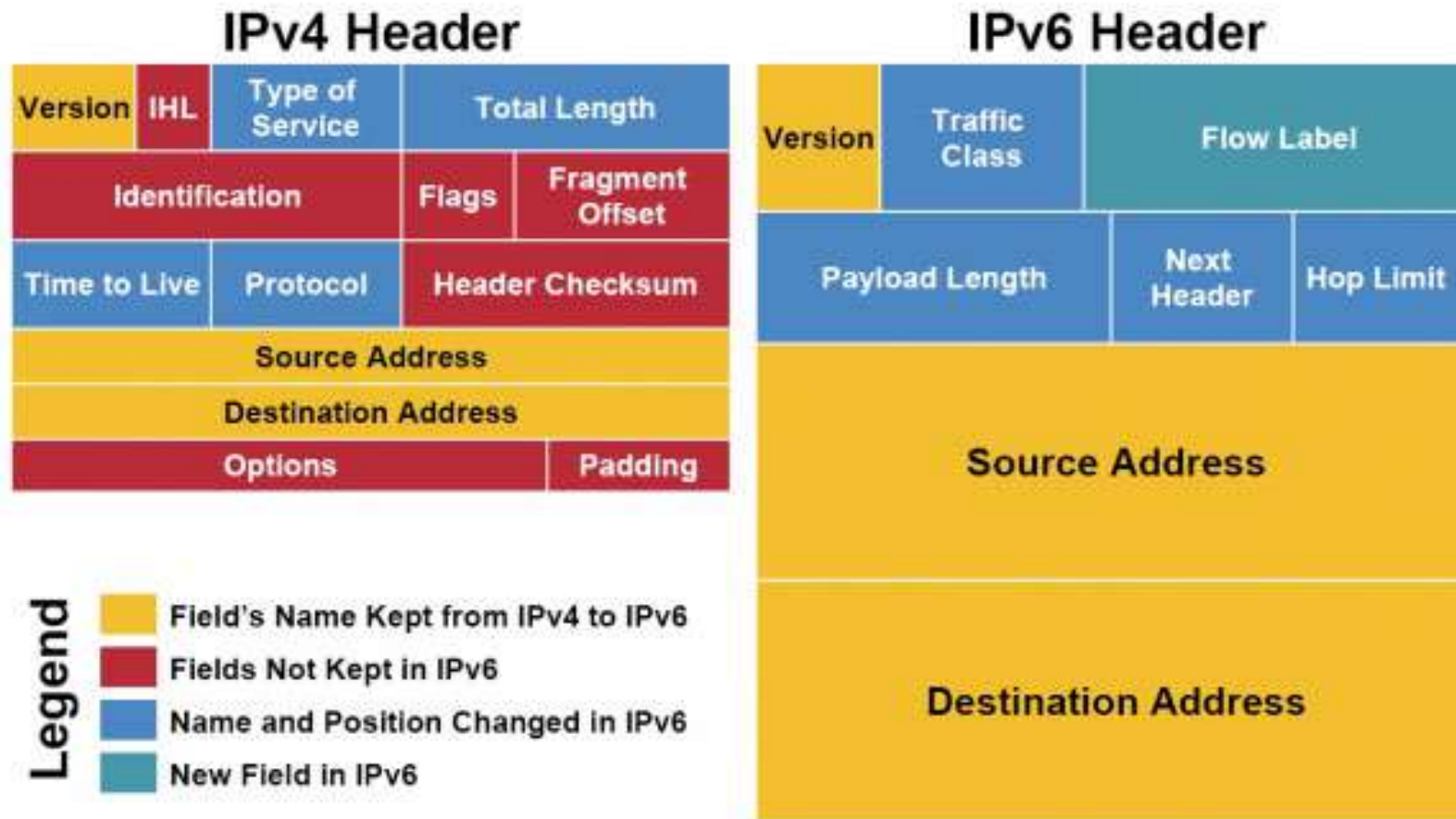
UDP Datagram



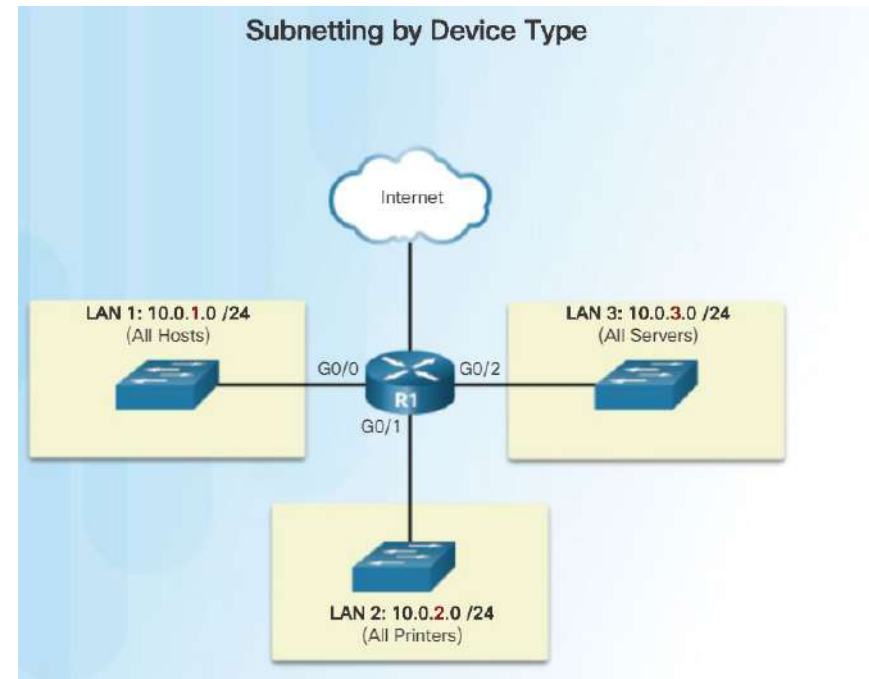
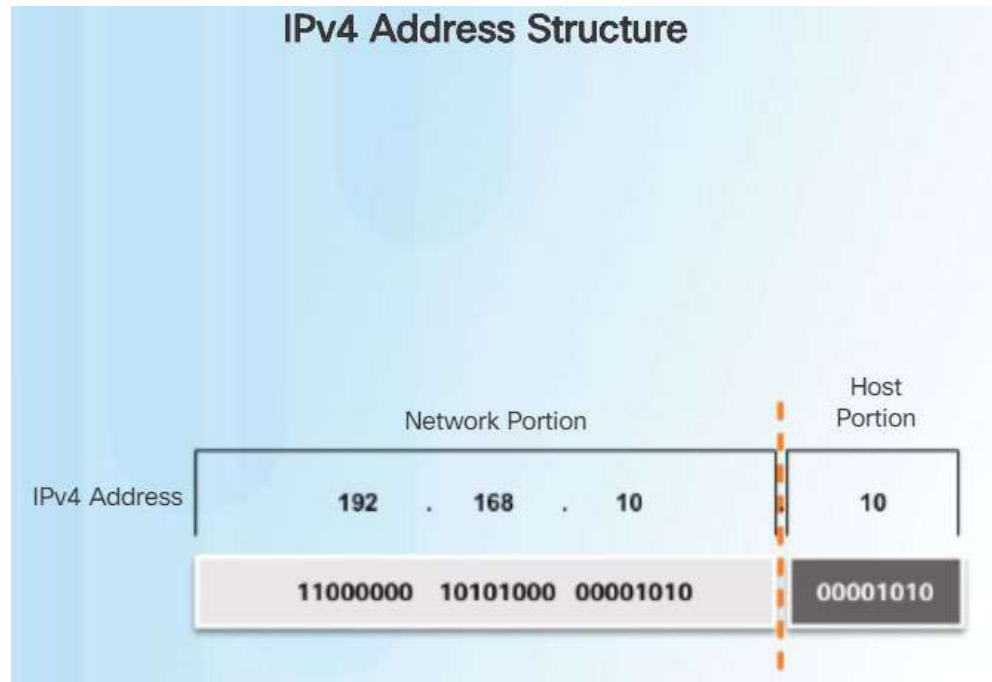
Síťové protokoly

- IPv4 a IPv6
- ICMP
- ARP

IPv4 a IPv6 protokol



IPv4 address subnetting



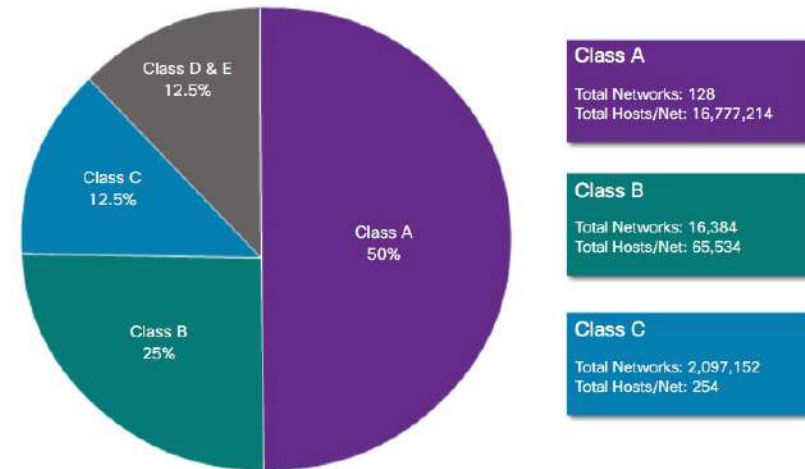
IPv4 adresace a subneting

- Třída A – 0.0.0.0 – 127.255.255.255
- Třída B – 128.0.0.0 - 191.255.255.255
- Třída C – 192.0.0.0 - 223.255.255.255
- Třída D – 224.0.0.0 - 239.255.255.255
- Třída E – 240.0.0.0 - 255.255.255.255

Private Internet Addresses are Defined in RFC 1918

Class	RFC 1918 Internal Address Range
A	10.0.0.0 - 10.255.255.255
B	172.16.0.0 - 172.31.255.255
C	192.168.0.0 - 192.168.255.255

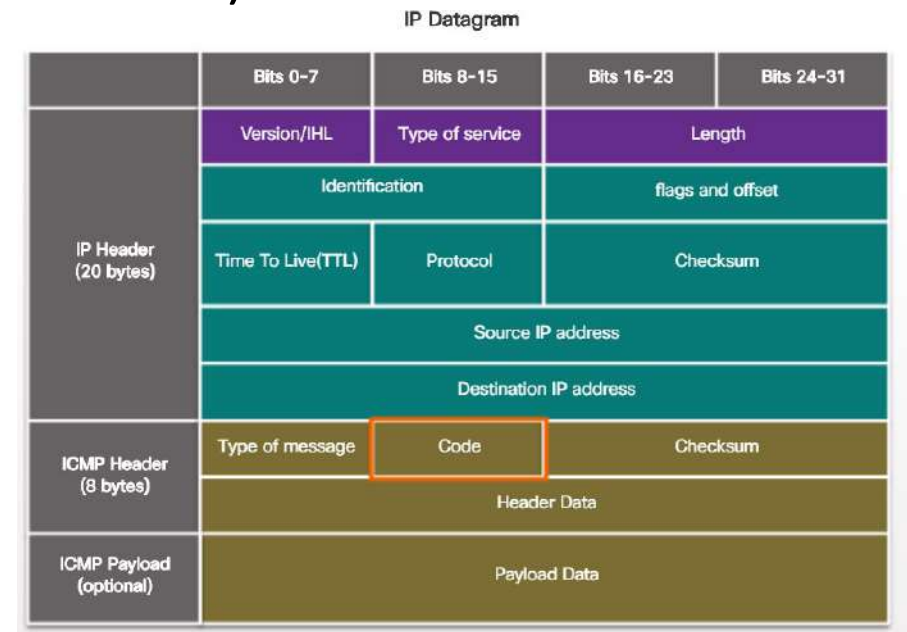
Summary of Classful Addressing



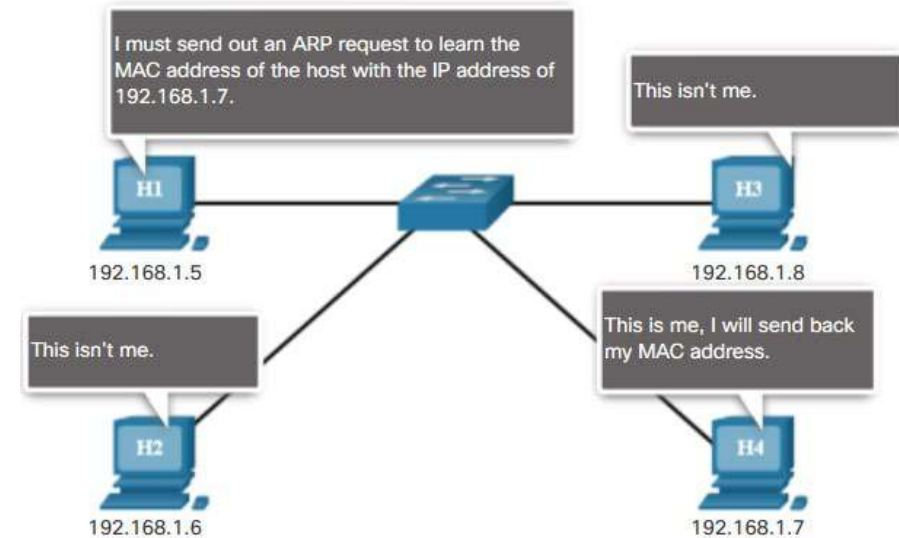
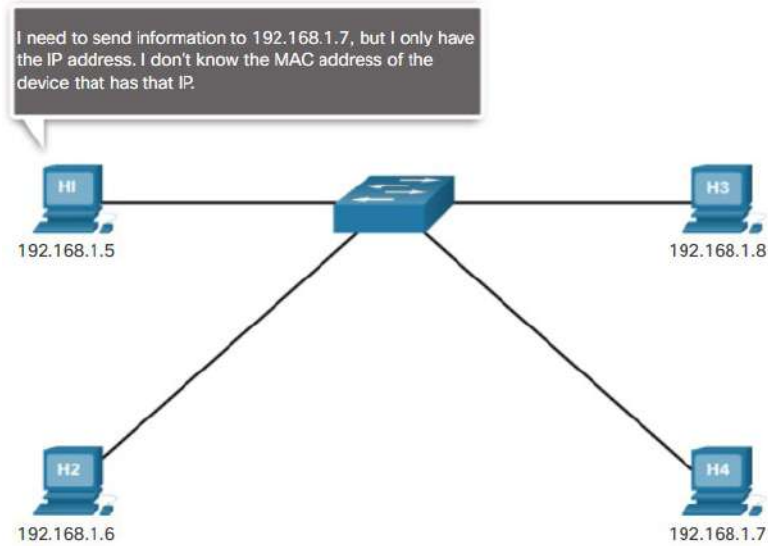
ICMP protokol

ICMP zprávy

- **0** – Echo reply (response to a ping)
- **3** – Destination Unreachable
- **5** – Redirect (use another route to your destination)
- **8** – Echo request (for ping)
- **11** – Time Exceeded (TTL became 0)



Address Resolution Protocol



Address Resolution Protocol

```
C:\Users\MiroslavBureš>arp -a
```

```
Interface: 192.168.189.1 --- 0x4
```

Internet Address	Physical Address	Type
192.168.189.254	00-50-56-fa-e0-3e	dynamic
192.168.189.255	ff-ff-ff-ff-ff-ff	static
224.0.0.22	01-00-5e-00-00-16	static
224.0.0.251	01-00-5e-00-00-fb	static
224.0.0.252	01-00-5e-00-00-fc	static
239.255.255.250	01-00-5e-7f-ff-fa	static
239.255.255.255	01-00-5e-7f-ff-ff	static
255.255.255.255	ff-ff-ff-ff-ff-ff	static

```
Interface: 192.168.65.1 --- 0xb
```

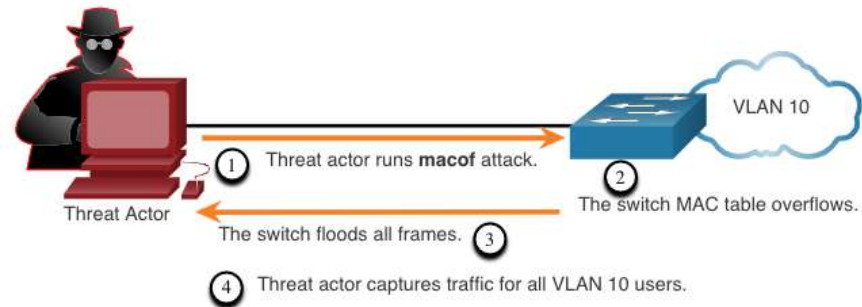
Internet Address	Physical Address	Type
192.168.65.254	00-50-56-f8-98-b2	dynamic
192.168.65.255	ff-ff-ff-ff-ff-ff	static
224.0.0.22	01-00-5e-00-00-16	static
224.0.0.251	01-00-5e-00-00-fb	static
224.0.0.252	01-00-5e-00-00-fc	static
239.255.255.250	01-00-5e-7f-ff-fa	static
239.255.255.255	01-00-5e-7f-ff-ff	static
255.255.255.255	ff-ff-ff-ff-ff-ff	static

ÚTOKY NA POČÍTAČOVOU SÍŤ

Útoky na L2 vrstvě

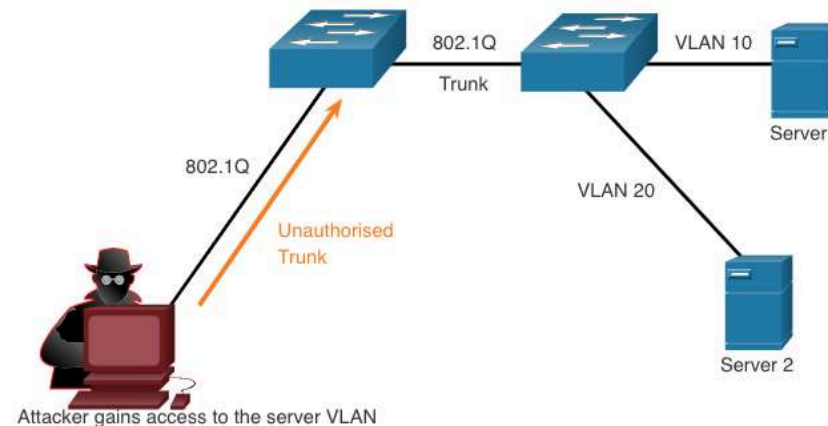
- MAC Table Attacks
- VLAN Attacks
- DHCP Attacks
- ARP Attacks
- Address Spoofing Attacks
- STP Attacks

MAC Address Table Flooding



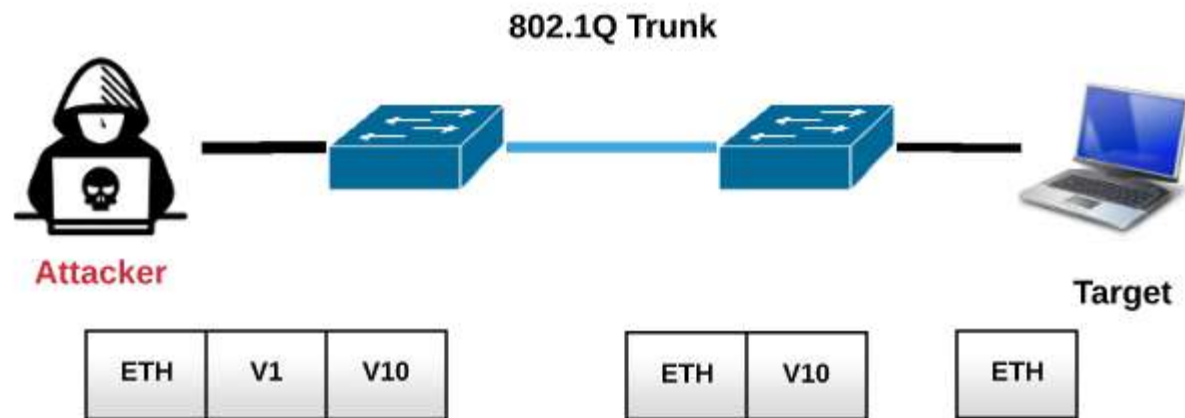
- Řešení -> používání port security, 802.1X

VLAN Hopping Attacks



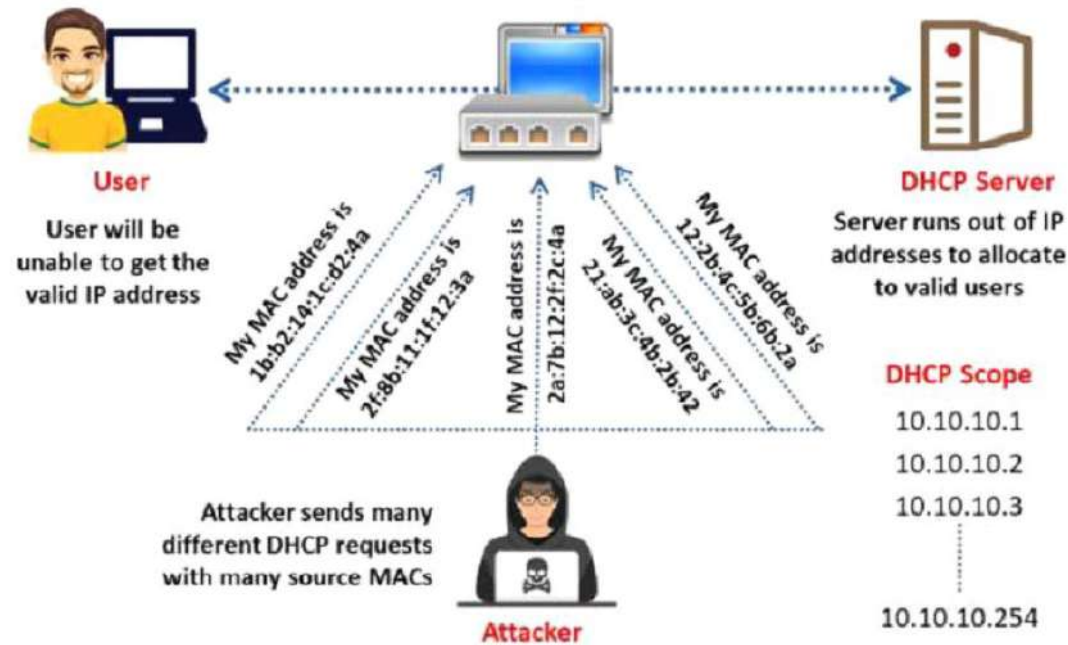
- Řešení -> nepoužívat protokol DTP, vypnout trunky na nepoužívaných portech, použití nativní VLANy pouze na truncích

VLAN Double-Tagging Attacks



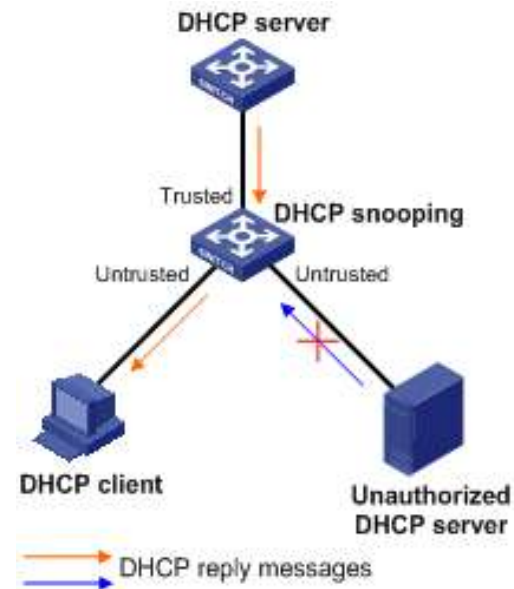
- Řešení -> nepoužívat protokol DTP, vypnout trunky na nepoužívaných portech, použití nativní VLANy pouze na troncích

DHCP Starvation Attack



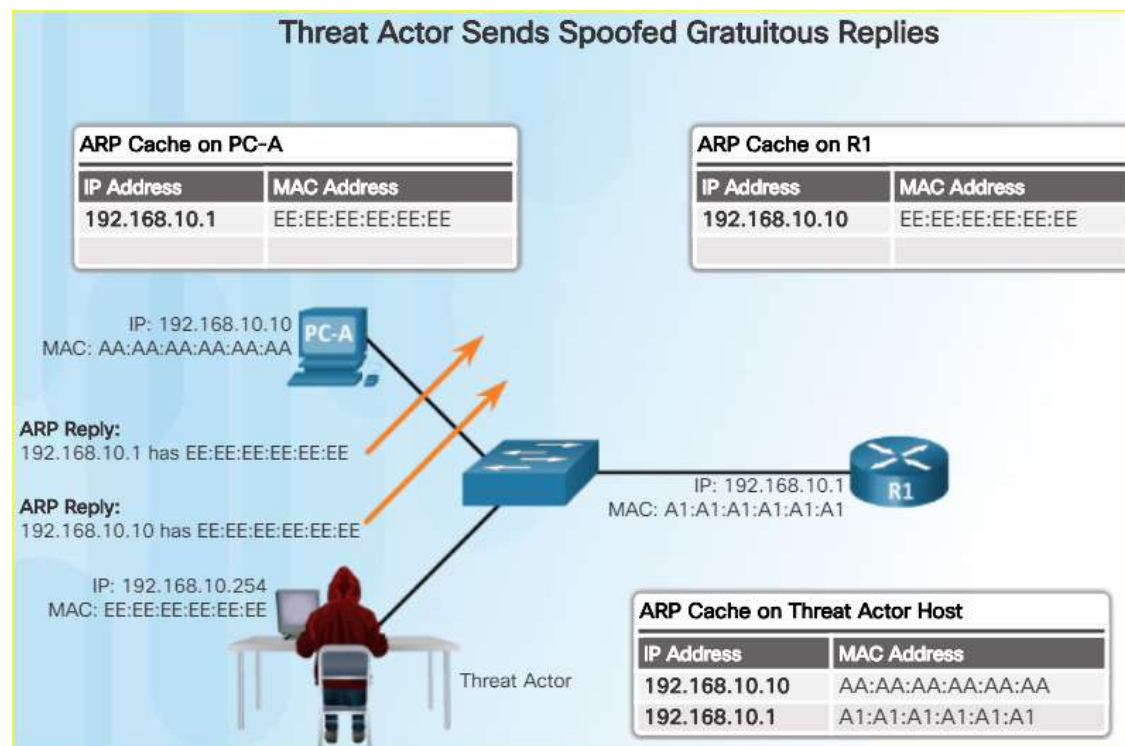
- Řešení -> používat port security

DHCP Spoofing Attack



- Řešení -> konfigurace *ip dhcp snooping*

Address spoofing attack/ARP cache poisoning



- Řešení -> používání port security, 802.1X, IP Source Guard

Útoky na L2 vrstvě

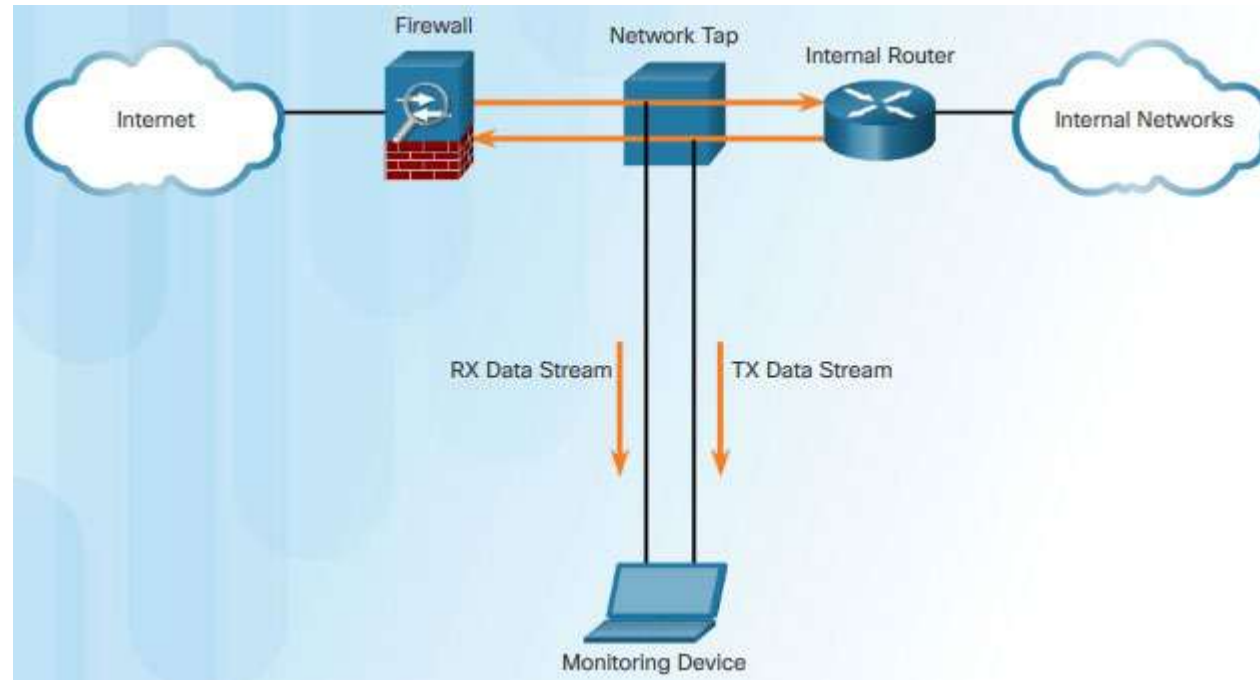
- Scapy
- Yersinia
- Macof
- Arpspoof
- ...

LOGOVÁNÍ A ANALÝZA PROVOZU

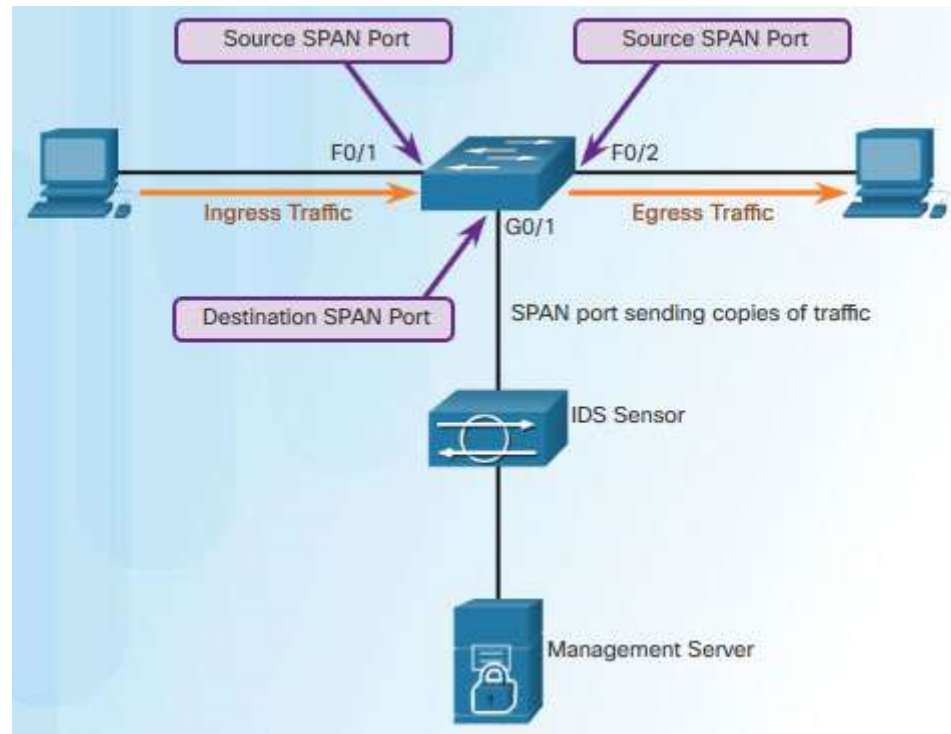
Síťový monitoring



Network Tap



Traffic Mirroring and SPAN



Wireshark, tcpdump, Tshark

The image shows a Wireshark window titled "RDM checksum error on man specific pid of overflow packets.pcapng". The interface displays a list of captured packets in the packet list pane, with packet 22 selected. The packet details pane shows the structure of the selected packet, and the packet bytes pane shows the raw data in hexadecimal and ASCII.

Packet List:

No.	Time	Source	Destination	Protocol	Length	Info
15	0.000000	2.5.5.5	2.255.255.255	ARTNET	85	[ArtDiagData] PRODUCT NOT COMMISSIONED
16	0.001935	2.5.5.5	255.255.255.255	ARTNET	282	[ArtPollReply] Circuit 1 In: 0 Out: 1
17	0.000247	2.5.5.5	255.255.255.255	ARTNET	282	[ArtPollReply] Circuit 2 In: 0 Out: 2
18	0.000310	2.5.5.5	255.255.255.255	ARTNET	282	[ArtPollReply] Circuit 3 In: 0 Out: 3
19	0.000291	2.5.5.5	255.255.255.255	ARTNET	282	[ArtPollReply] Circuit 4 In: 0 Out: 4
20	0.000224	2.5.5.5	255.255.255.255	ARTNET	76	[ArtIpProgReply] IP:2.5.5.5 Mask:255.0.0.0 Port:6454
21	0.001683	2.5.5.5	2.255.255.255	ARTNET	138	[ArtDiagData] Desired power = 5000mW, Allocated power = 0mW, uPOE = 0, POE+ = 0, POE = 0
22	0.000640	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 1, Src: 414c:fefefe01, Dst: ffff:ffffff
23	0.000242	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 1, Src: 414c:fefefe02, Dst: ffff:ffffff
24	0.000248	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 1, Src: 414c:fefefe03, Dst: ffff:ffffff
25	0.000250	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 2, Src: 414c:fefefe04, Dst: ffff:ffffff
26	0.004144	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 2, Src: 414c:fefefe05, Dst: ffff:ffffff
27	0.000235	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 2, Src: 414c:fefefe06, Dst: ffff:ffffff
28	0.000254	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 3, Src: 414c:fefefe07, Dst: ffff:ffffff
29	0.000240	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 3, Src: 414c:fefefe08, Dst: ffff:ffffff
30	0.004223	2.5.5.5	255.255.255.255	RDM	123	[ArtRdm] Universe: 3, Src: 414c:fefefe09, Dst: ffff:ffffff

Packet Details:

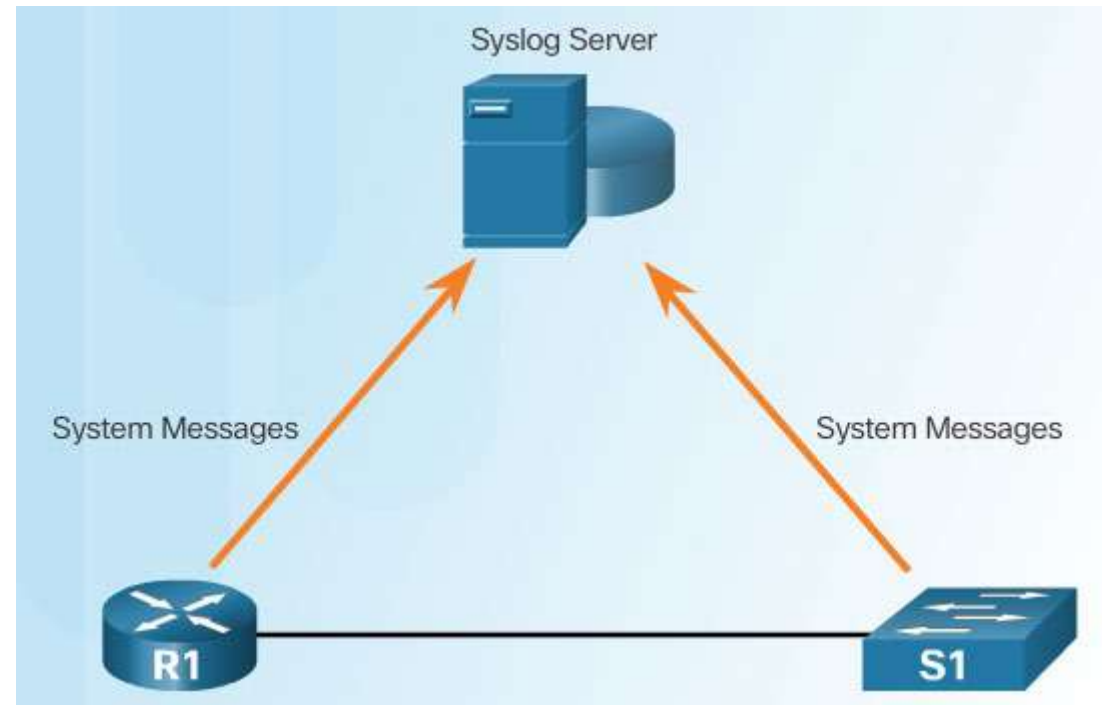
- Frame 22: 123 bytes on wire (984 bits), 123 bytes captured (984 bits) on interface \Device\NPF_{E1EB8752-085B}
- Ethernet II, Src: Artistic_06:07:08 (00:06:a6:06:07:08), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
- Internet Protocol Version 4, Src: 2.5.5.5, Dst: 255.255.255.255
- User Datagram Protocol, Src Port: 6454, Dst Port: 6454
- Art-Net, Opcode: ArtRdm (0x8300)
 - Descriptor Header
 - ArtRdm packet
 - Remote Device Management, Src: 414c:fefefe01, Dst: ffff:ffffff
 - Sub-start code: 0x01
 - Message length: 56
 - Destination UID: ffffffff
 - Source UID: 414c:fefefe01
 - Transaction number: 0
 - Response type: Ack (0x00)
 - Message count: 0
 - Sub-device: 0
 - Message Data Block
 - Command class: Get Command Response (0x21)
 - Parameter ID: DEVICE_LABEL (0x0082)
 - Parameter data length: 32
 - Parameter data
 - Device Label: Circuit 1 DALI Broadcast

Packet Bytes:

```
0000  ff ff ff ff ff ff 00 06  a6 06 07 08 00 45 00  .....E:
0010  00 6d 00 0a 00 00 64 11  4f 6d 02 05 05 05 ff ff  -m...d...Om-----
0020  ff ff 19 36 19 36 00 59  a3 c7 41 72 74 2d 4e 65  ...6.6.Y...Art-Ne
0030  74 00 00 83 00 0e 01 00  00 00 00 00 00 00 00 00  t-----
0040  00 01 01 38 ff ff ff ff  ff ff 41 4c fe fe fe 01  ...8....AL....
0050  00 00 00 00 00 21 00 82  20 43 69 72 63 75 69 74  ....]...Circuit
0060  20 31 20 44 41 4c 40 20  42 72 6f 61 64 63 61 73  1 DALI Broadcas
0070  74 00 00 00 00 00 00 00  00 13 5b                    t-----[
```

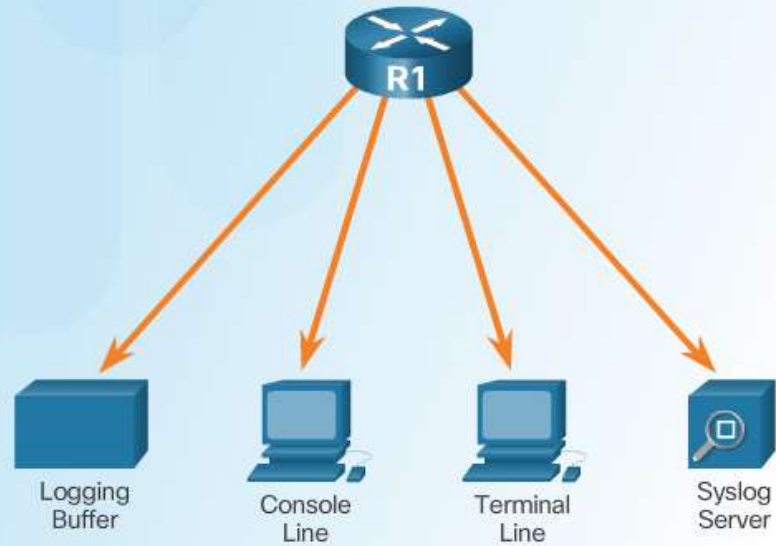
Art-Net: Protocol | Packets: 402 · Displayed: 219 (54.5%) | Profile: Default

Syslog



Syslog

```
R1(config-if)# no shutdown
R1(config-if)#
000047: *Feb 19 11:36:47.779: %LINK-3-UPDOWN: Interface Serial0/0/0, changed
state to up
000048: *Feb 19 11:36:48.779: %LINEPROTO-5-UPDOWN: Line protocol on Interface
Serial0/0/0, changed state to up
```



Syslog

	Level	Keyword	Description	Definition
Highest Level	0	emergencies	System is unusable	LOG_EMERG
	1	alerts	Immediate action is needed	LOG_ALERT
	2	critical	Critical conditions exist	LOG_CRIT
	3	errors	Error conditions exist	LOG_ERR
	4	warnings	Warning conditions exist	LOG_WARNING
	5	notifications	Normal but significant condition	LOG_NOTICE
	6	informational	Informational messages only	LOG_INFO
Lowest Level	7	debugging	Debugging messages	LOG_DEBUG

Syslog Level and Name	Definition	Example
0 LOG_EMERG	A panic condition normally broadcast to all users	Cisco IOS software could not load
1 LOG_ALERT	A condition that should be corrected immediately, such as a corrupted system database	Temperature too high
2 LOG_CRIT	Critical conditions; for example, device errors	Unable to allocate memory
3 LOG_ERR	Errors	Invalid memory size
4 LOG_WARNING	Warning messages	Crypto operation failed
5 LOG_NOTICE	Non-error conditions that may require special handling	Interface changed state, up or down
6 LOG_INFO	Informational messages	Packet denied by ACL
7 LOG_DEBUG	Messages that contain information that is normally used only when debugging a program	Packet type invalid

Syslog

1 2 3 4 5
000048: *Feb 19 11:36:48.779: %LINEPROTO-5-UPDOWN:
Line protocol on Interface Serial0/0/0, changed state to up
6

Column 1		Column 2
1	seq no	Stamps log messages with a sequence number if service sequence-numbers is configured.
2	timestamp	displays if service timestamps log is configured
3	facility	denotes the source or the cause of the system message
4	severity	levels 0 - 7
5	MNEMONIC	text string that uniquely describes the message
6	description	text string containing detailed information about the event being reported

Konfigurace Syslogu

Zapnutí logování na Cisco SW/R

logging userinfo

logging history debugging

logging trap debugging

logging origin-id hostname

logging host 10.60.61.81 transport udp port 1514

Konfigurace Syslogu

Logování zadávaných příkazu

archive

log config

logging enable

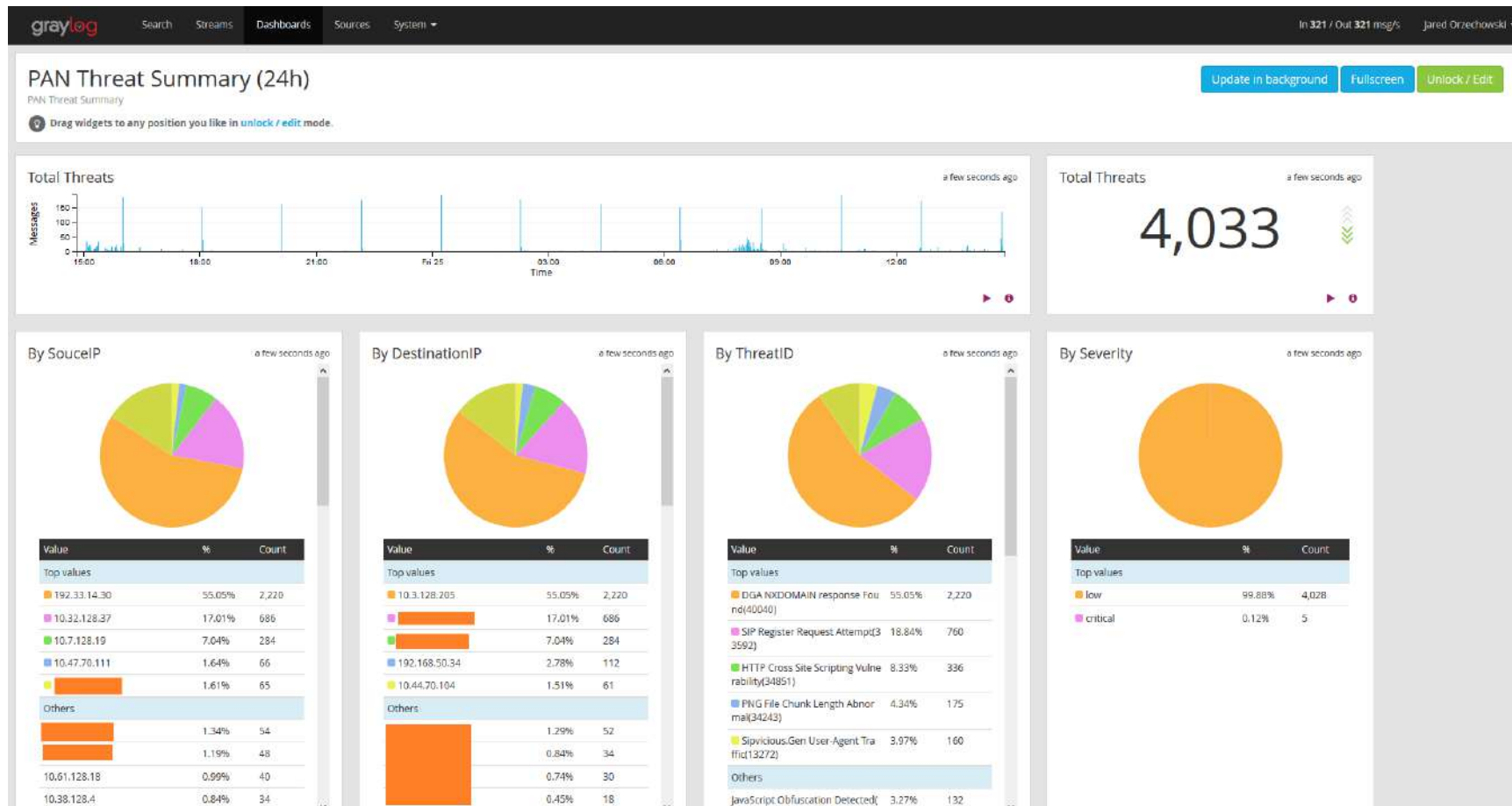
notify syslog contenttype plaintext

hidekeys

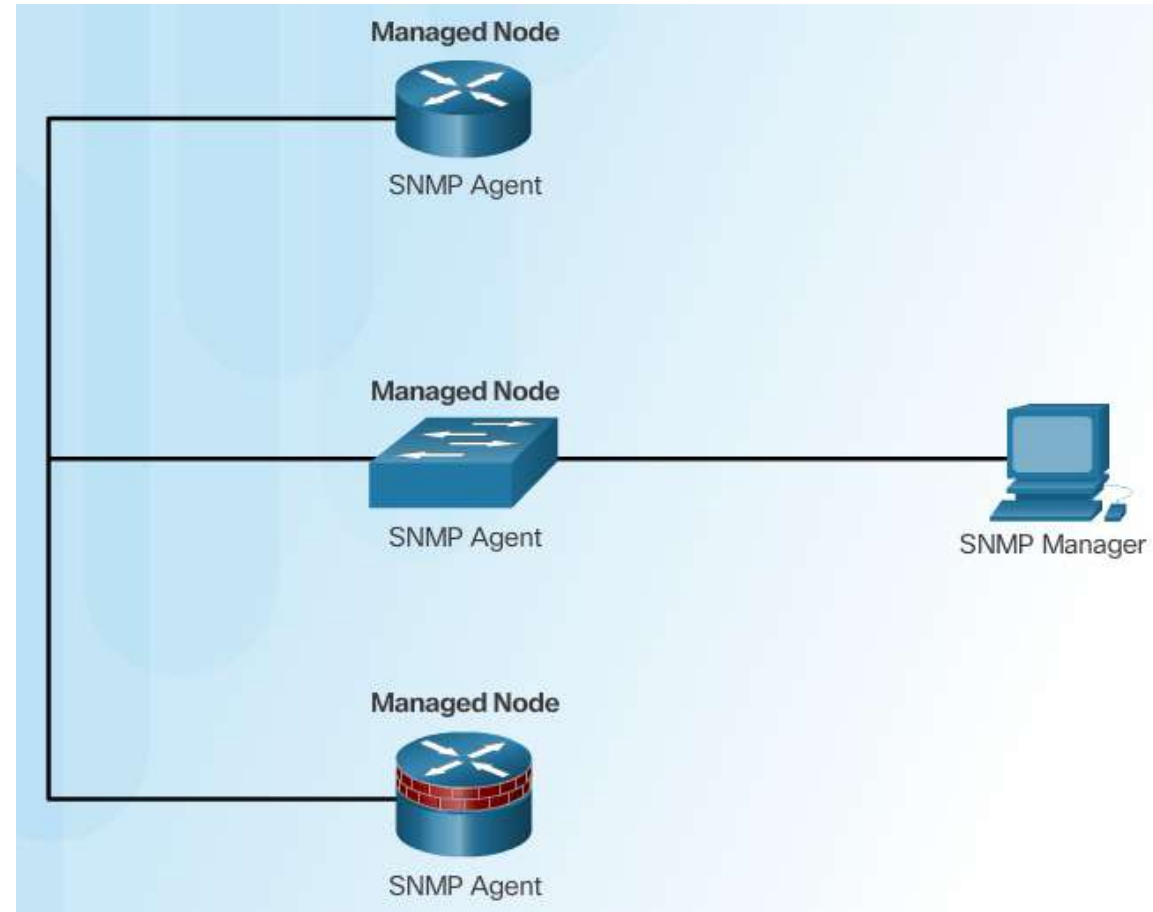
Syslog Server Software

- Kiwi Syslog Server
- Splunk Light
- Graylog

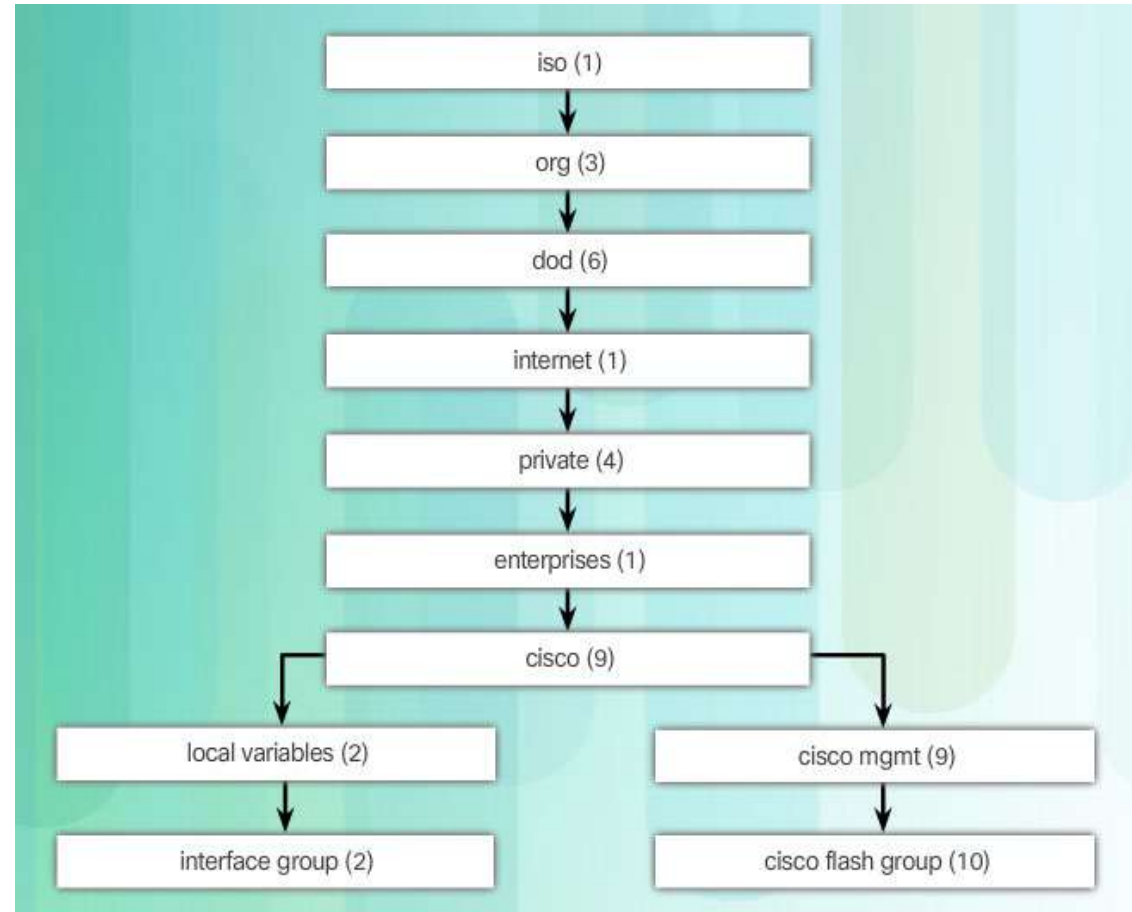
Graylog



SNMP



SNMP



SNMP

- Konfigurace SNMP na Cisco SW/R

```
snmp-server community StrongPassword RO [ACL-SNMP]
```

```
ip access-list standard ACL-SNMP
```

```
permit 10.10.10.10
```

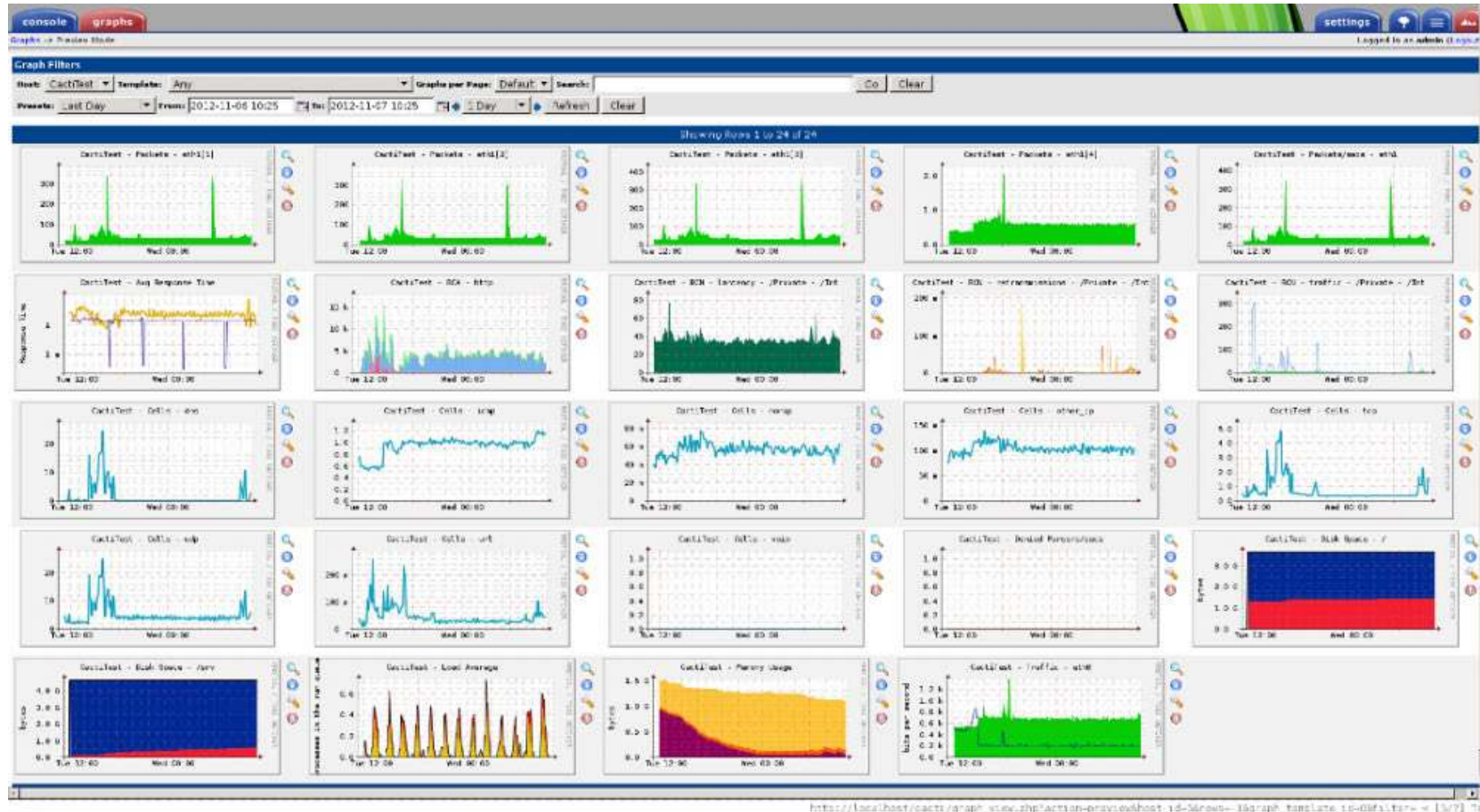
```
permit 10.20.20.20
```

SNMP

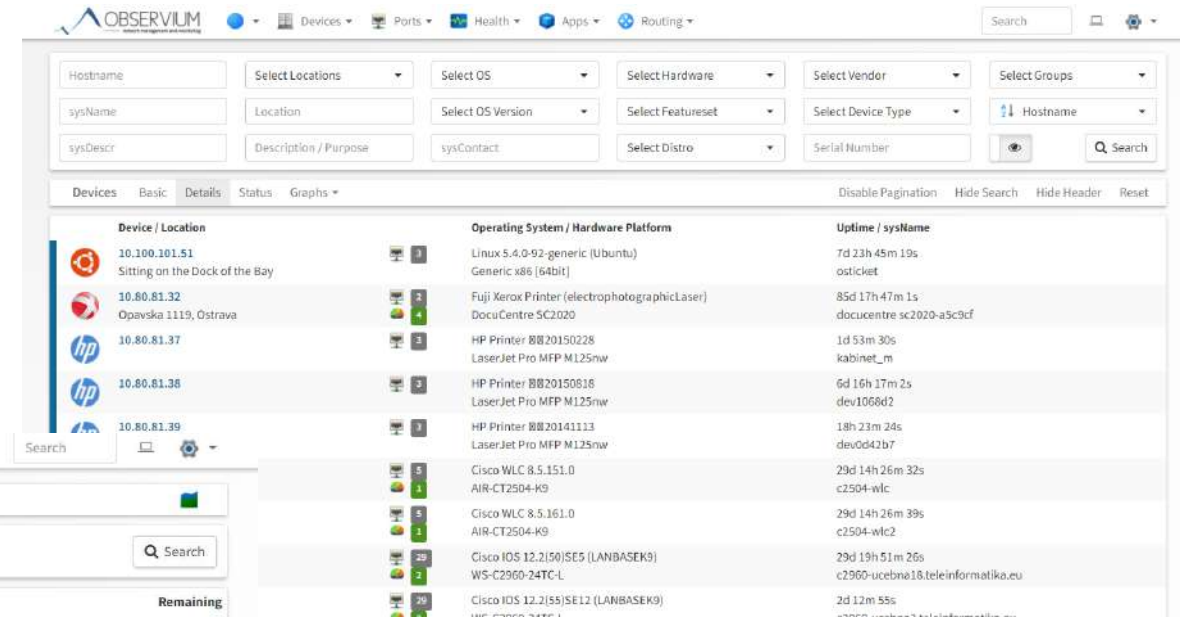
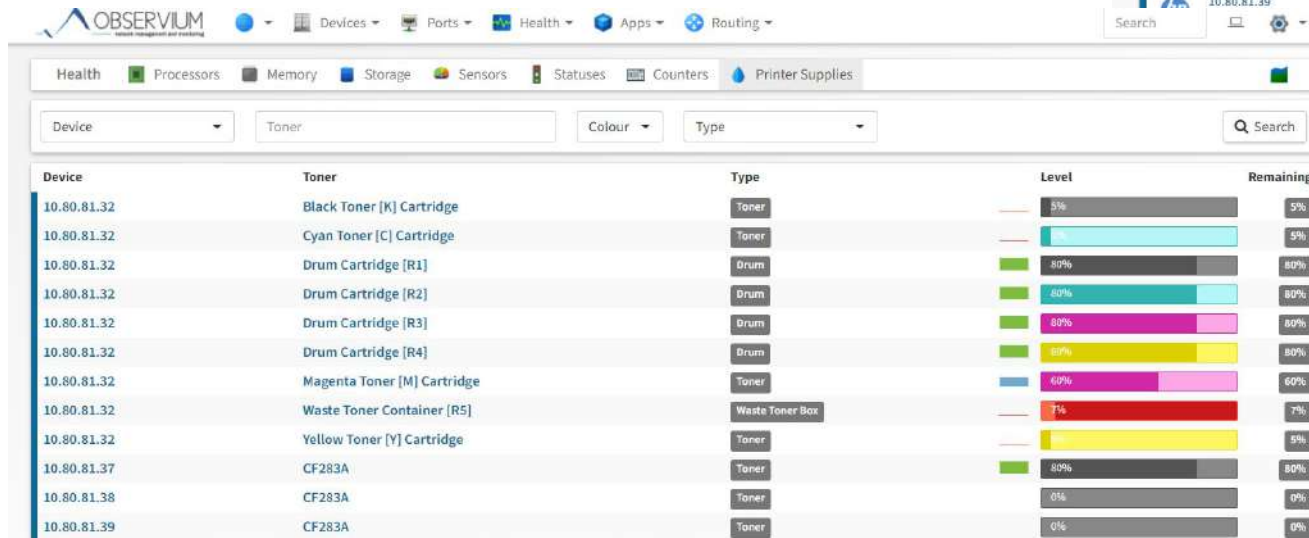
SNMPWALK

```
snmpwalk -v 2c -c Cylab123* 10.100.103.10 1.3.6.1.4.1.14179.2.1.1.1.38.8
```

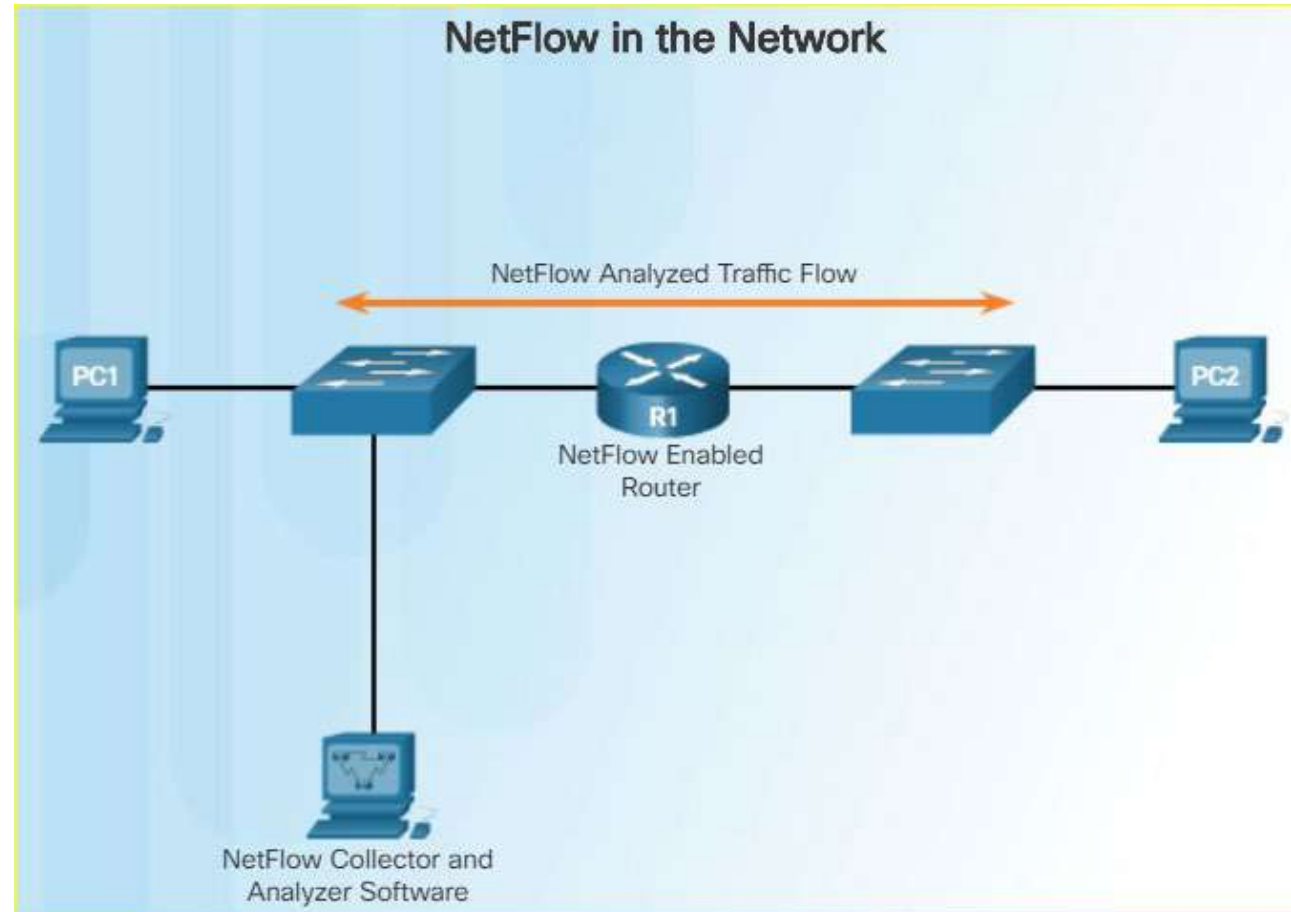
Cacti



Observium



NetFlow



NetFlow

Konfigurace na Cisco SW/R

```
ip flow-export source GigabitEthernet1/0/7
```

```
ip flow-export version 9
```

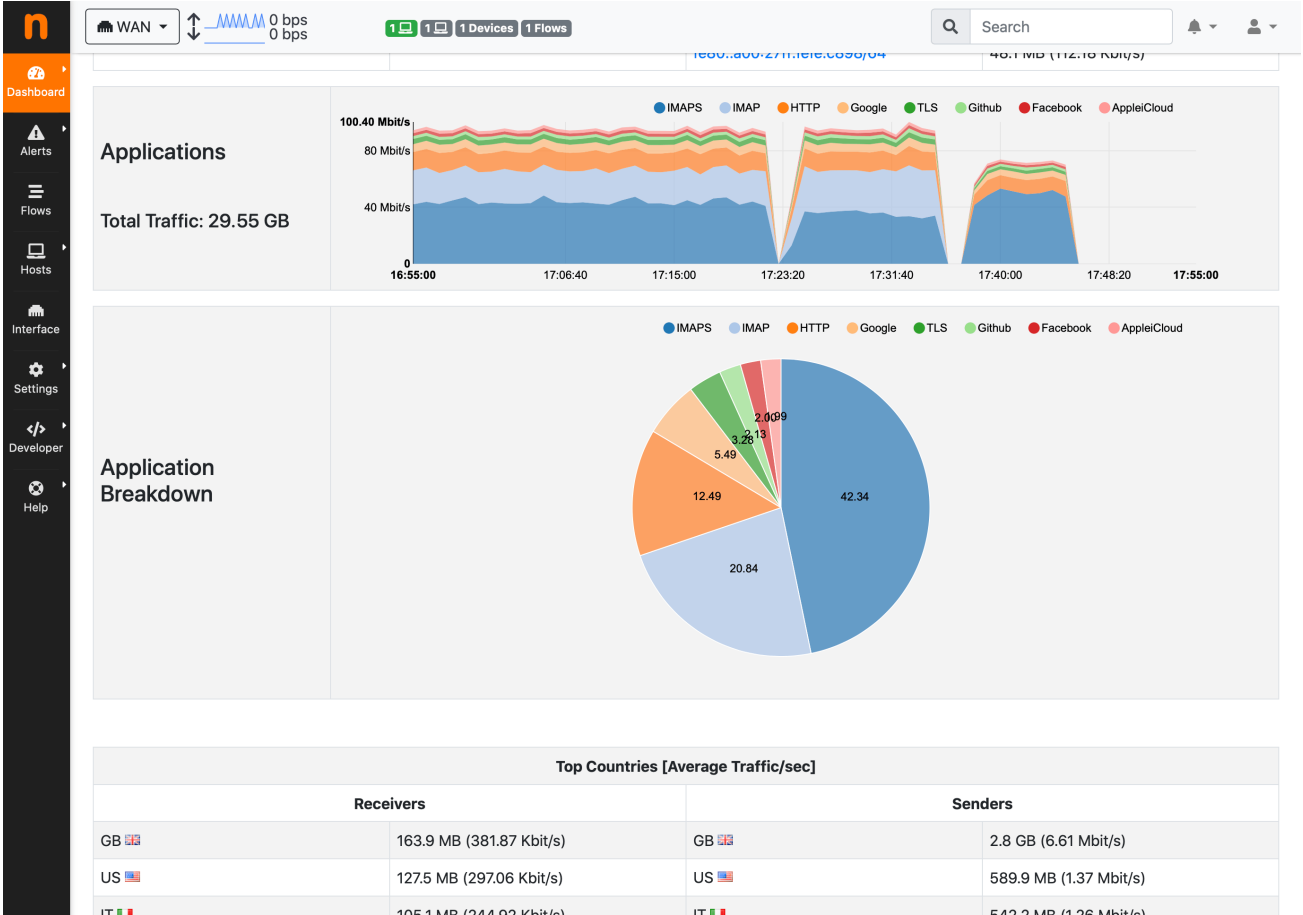
```
ip flow-export destination 10.60.61.82 2055
```

```
interface GigabitEthernet1/0/7
```

```
ip flow ingress
```

```
ip flow egress
```


Ntop



IDENTITY MANAGEMENT

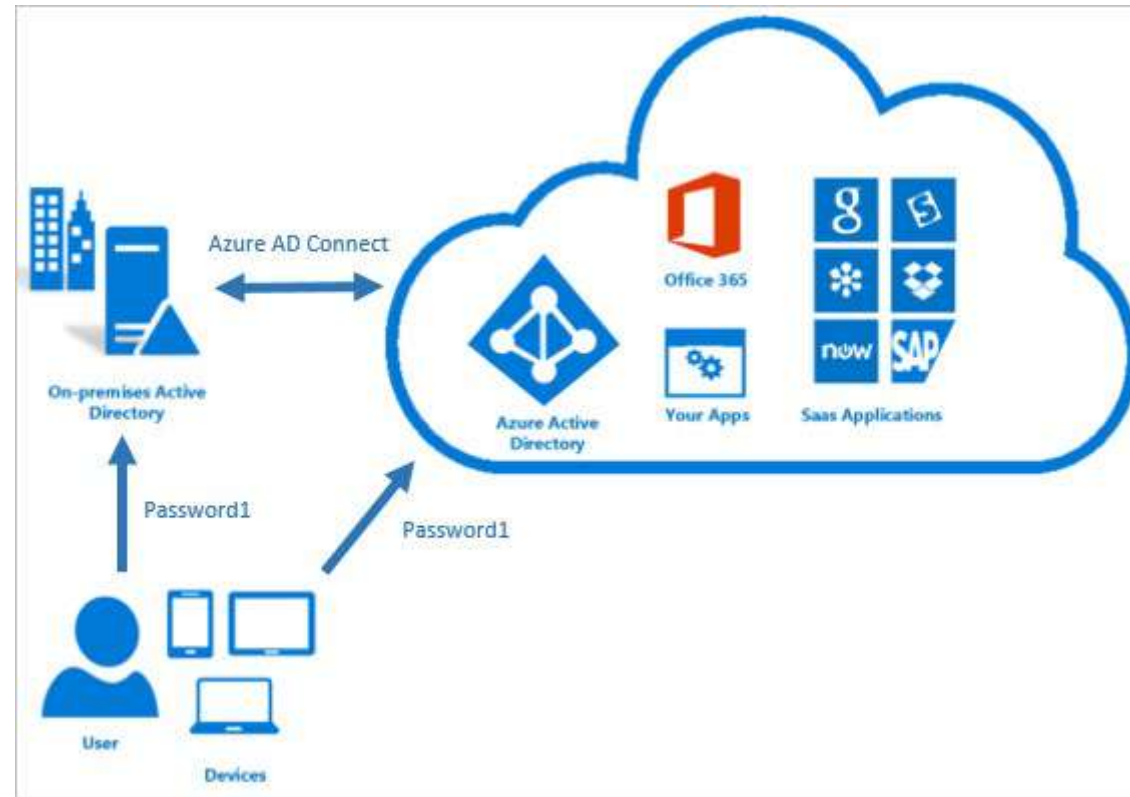
Identity management

LDAP x MS Active Directory -> **Single sign-on (SSO)**

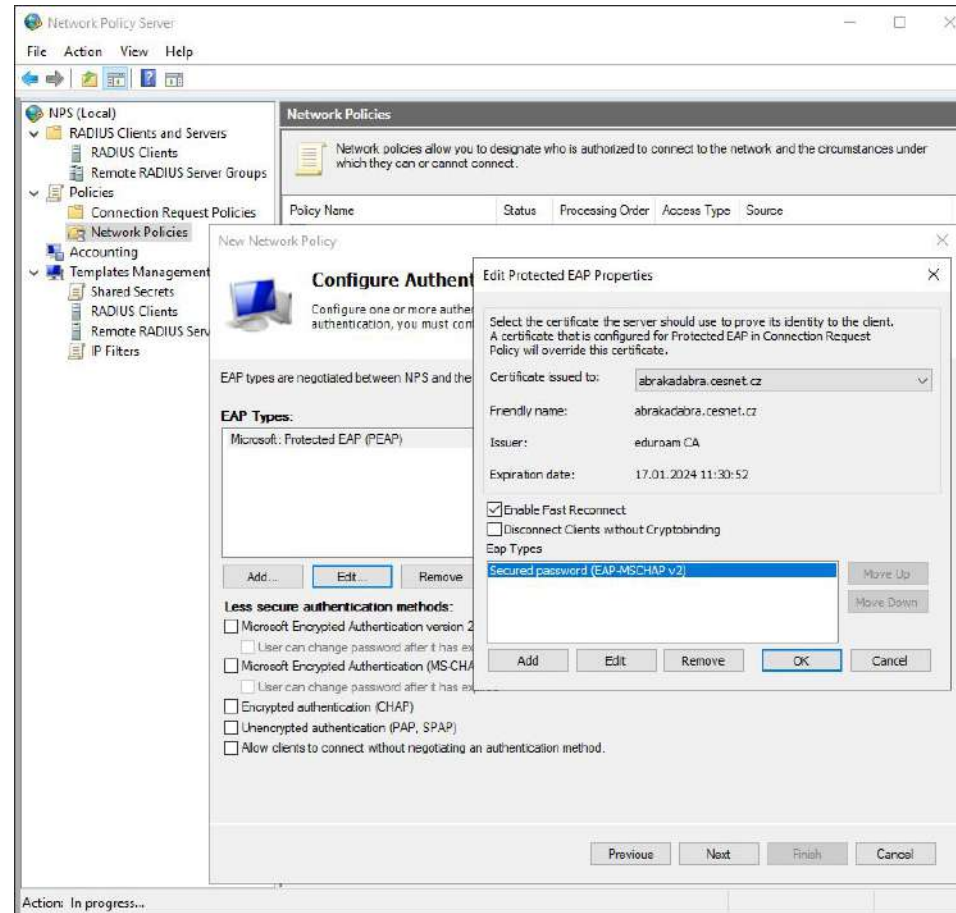
802.1X

- FreeRADIUS
- Radiator
- Microsoft NPS

MS Active Directory

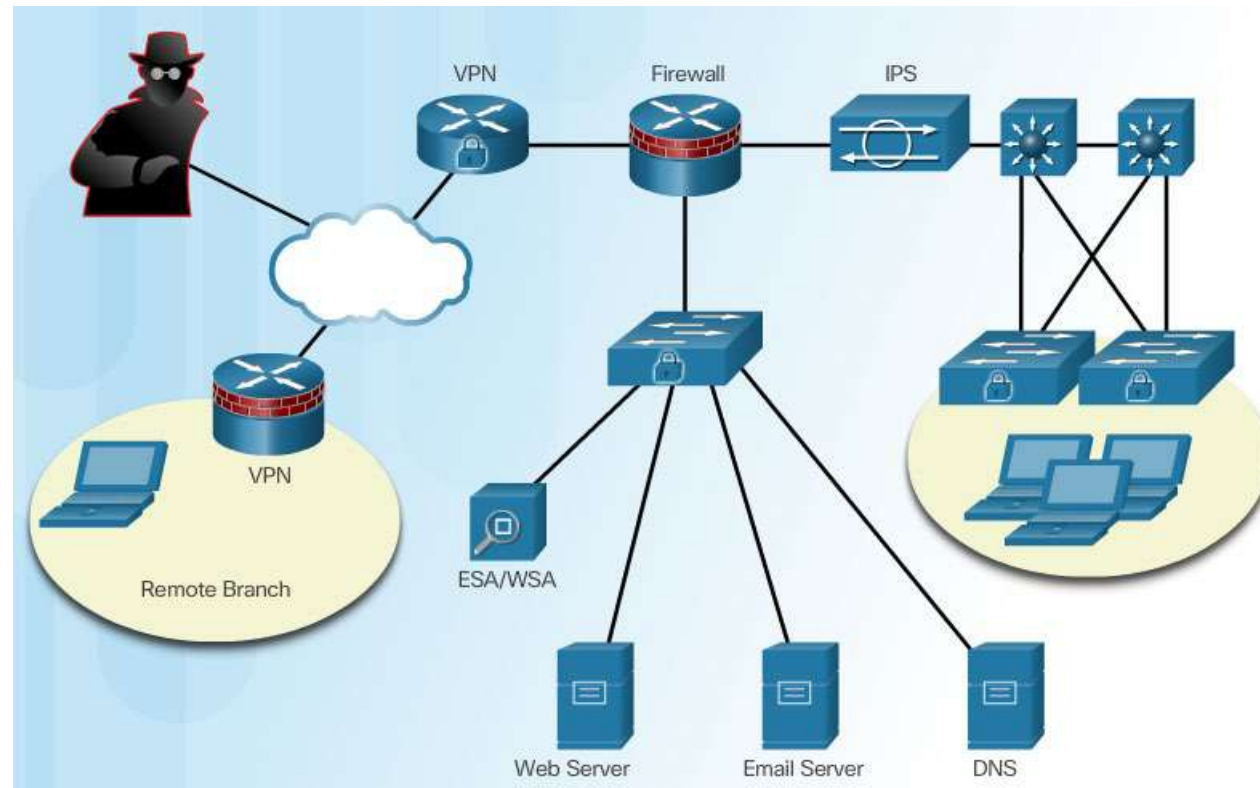


Network Policy Server (NPS)



ŠIFROVÁNÍ

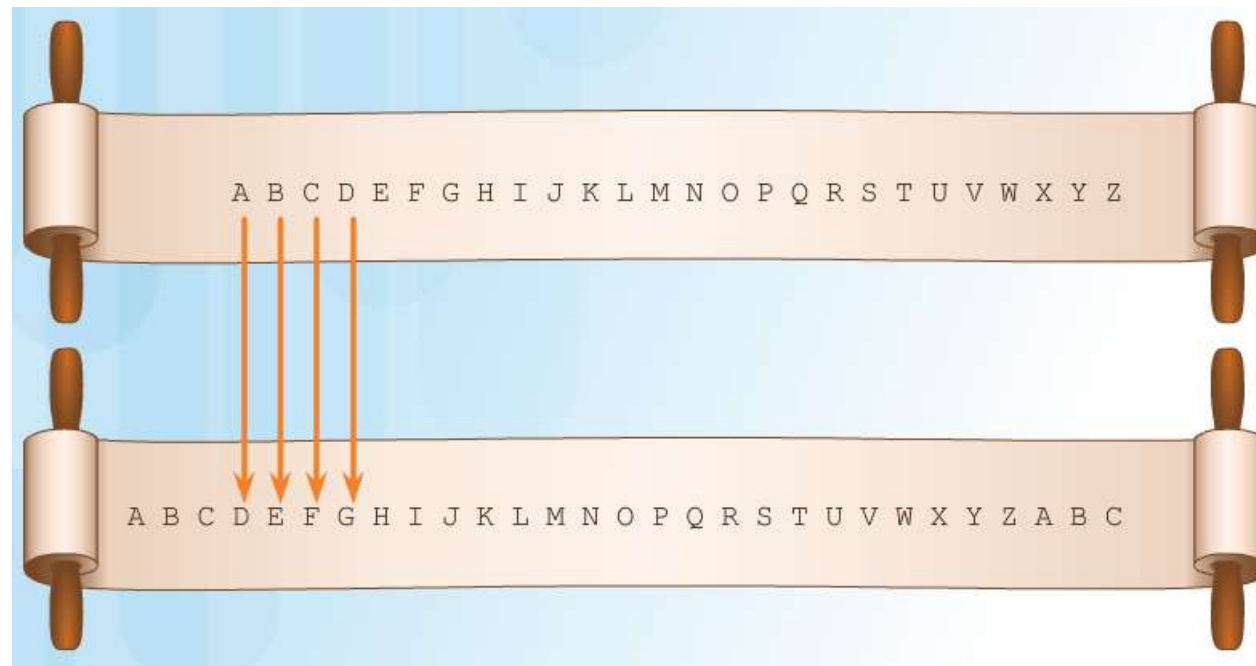
Autentizace, integrita a důvěrnost



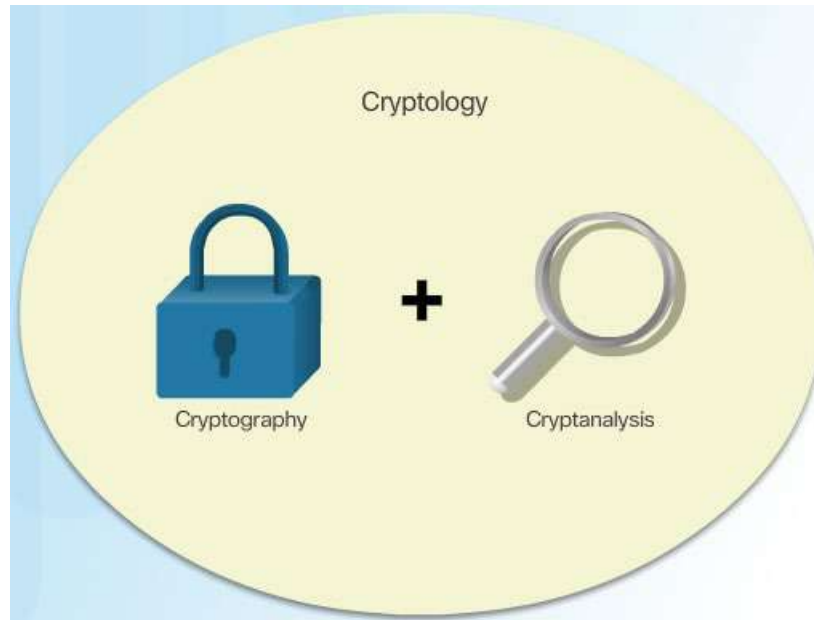
Šifrování

Typy šifer

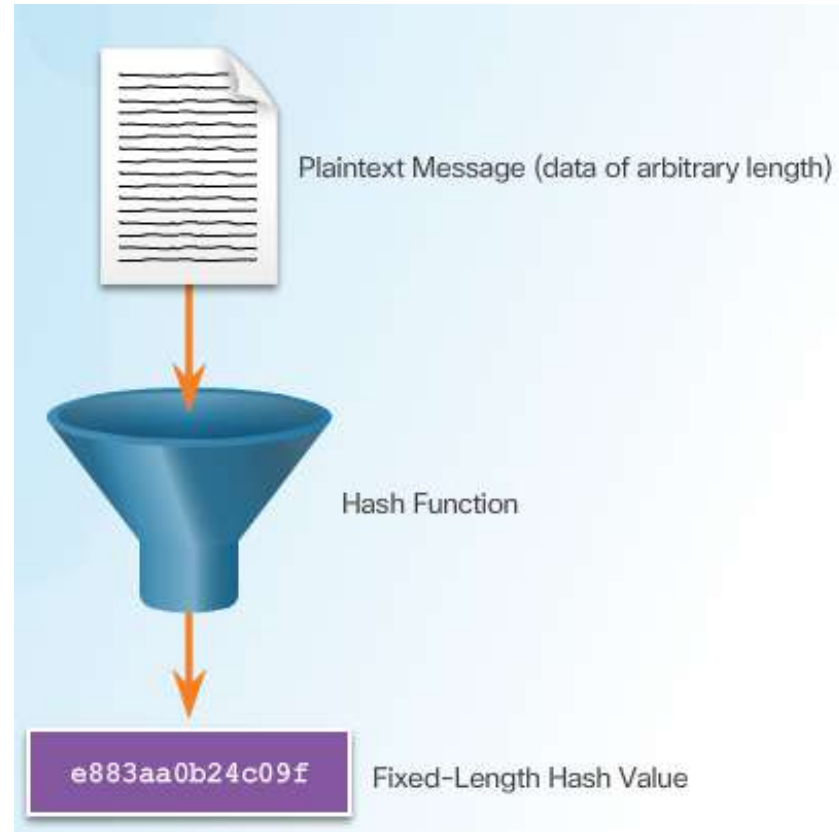
- transpoziční
- substituční
- jednorázová tabulková



Kryptologie = kryptografie + kryptoanalýza



Hash funkce



Hash funkce

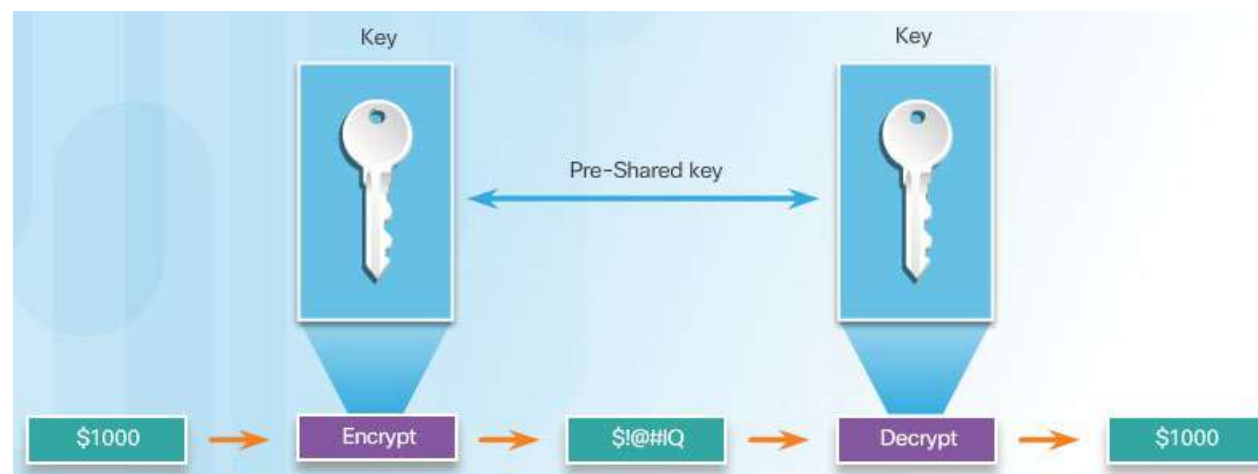
OpenSSL

openssl md5 <filename>

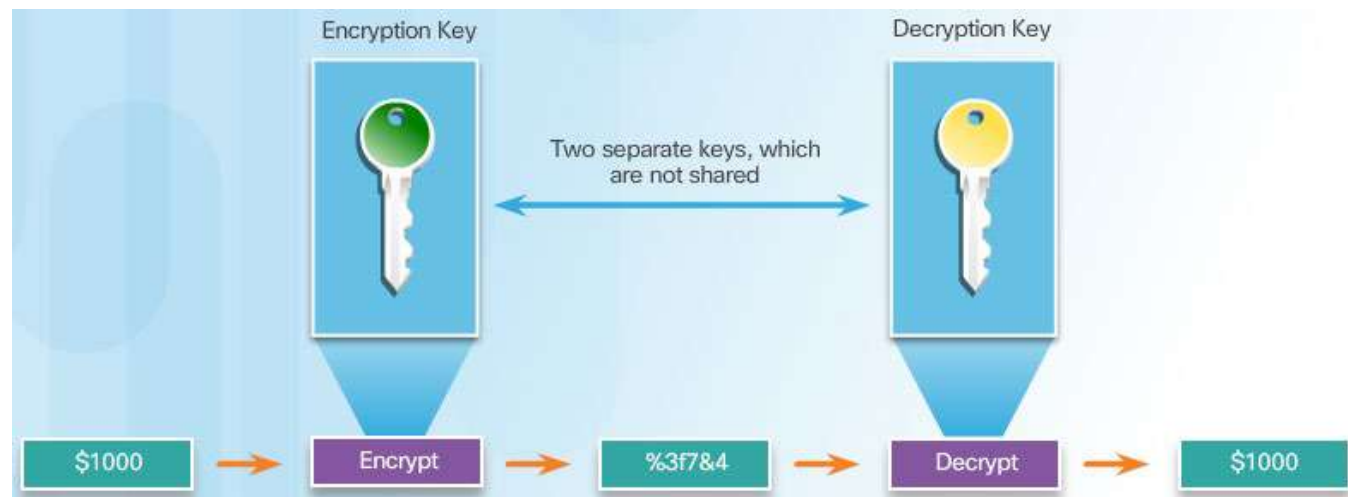
openssl sha1 <filename>

openssl sha256 <filename>

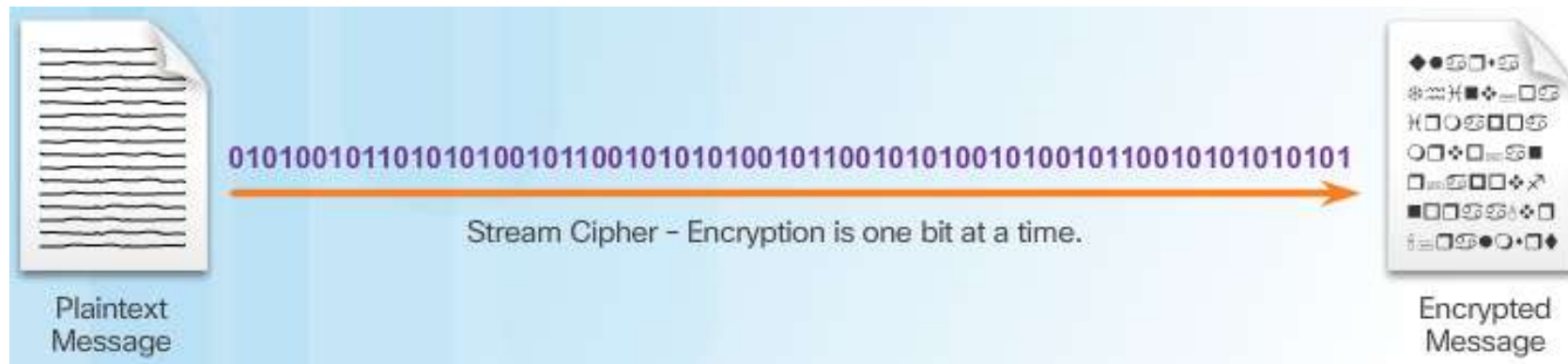
Symetrické šifrování



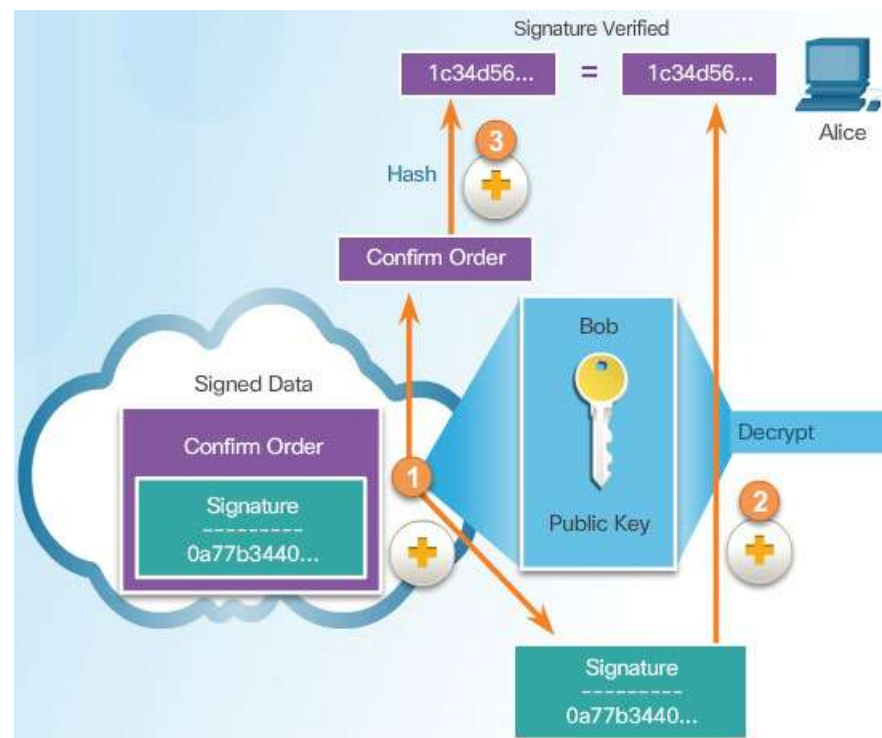
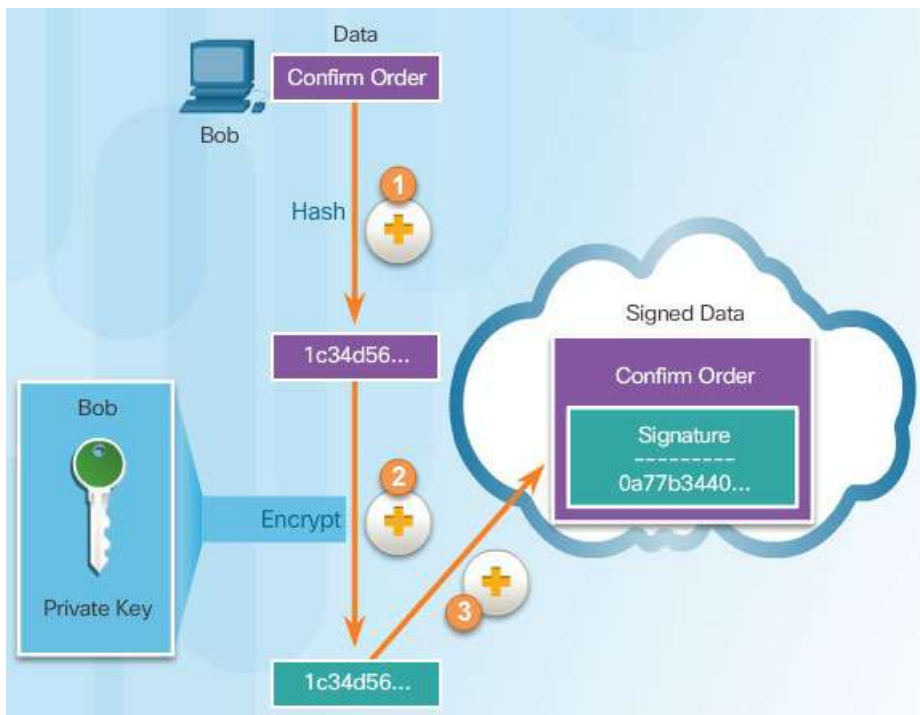
Asymetrické šifrování



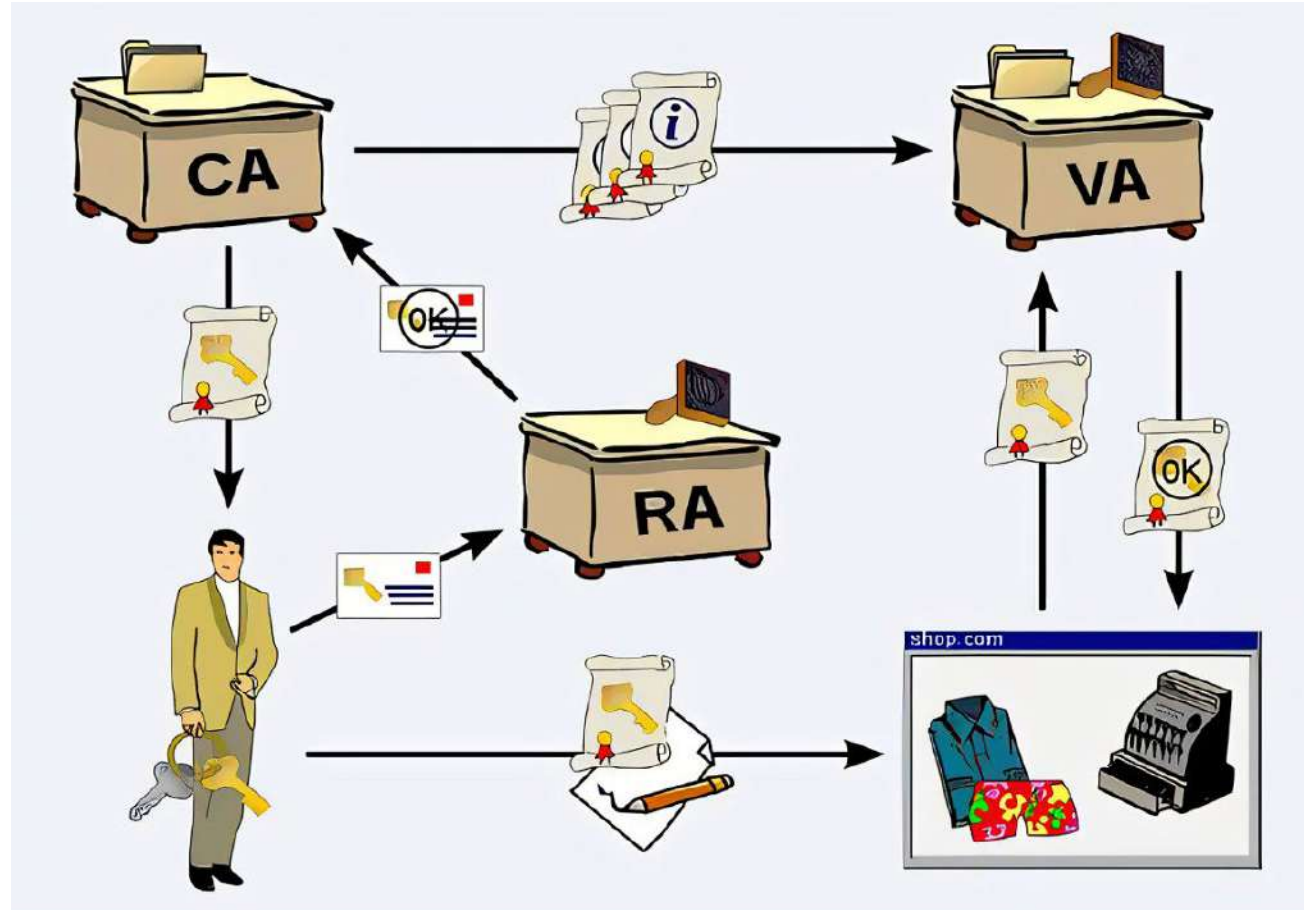
Blokové a proudové šifry



Digitální podpis

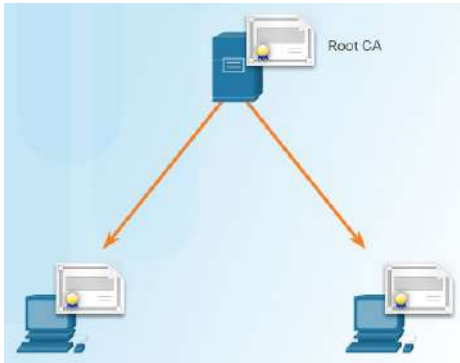


Public Key Infrastructure

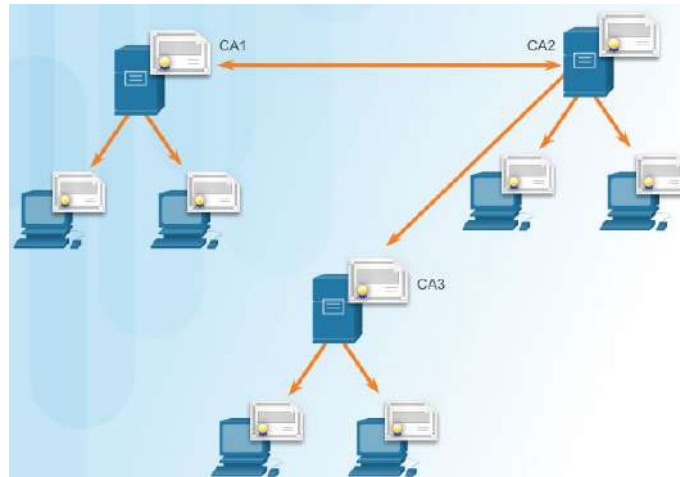


Public Key Infrastructure

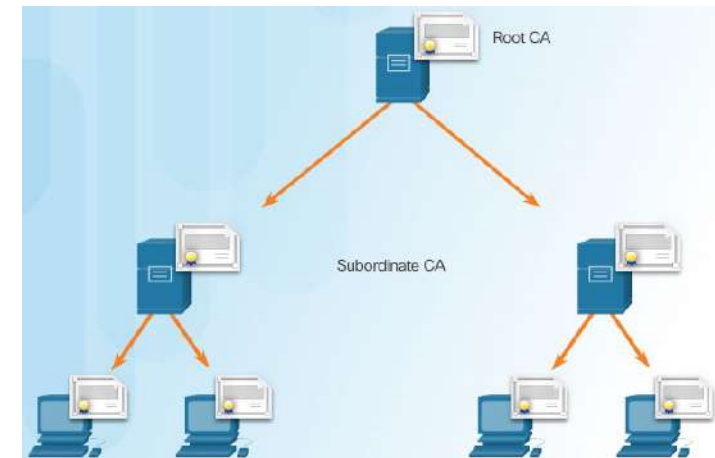
Single-Root PKI Topology



Cross Certified CA



Hierarchical CA



OpenSSL

Self-Signed Certificate

- openssl req -newkey rsa:2048 -nodes -keyout domain.key -out domain.csr
- openssl req -key domain.key -new -x509 -days 365 -out domain.crt
- openssl req -newkey rsa:2048 -nodes -keyout domain.key -x509 -days 365 -out domain.crt

OpenSSL

CA-Signed Certificate

- `openssl req -x509 -sha256 -days 1825 -newkey rsa:2048 -keyout rootCA.key -out rootCA.crt`
- `openssl x509 -req -CA rootCA.crt -CAkey rootCA.key -in domain.csr -out domain.crt -days 365 -CAcreateserial -extfile domain.ext`
- `domain.ext`
 - `authorityKeyIdentifier=keyid,issuer`
 - `basicConstraints=CA:FALSE`
 - `subjectAltName = @alt_names`
 - `[alt_names]`
 - `DNS.1 = domain`

OpenSSL

PEM to DER

- openssl x509 -in domain.crt -outform der -out domain.der

DER to PEM

- openssl x509 -inform der -in domain.der -out domain.crt

PEM to PKCS7

- openssl crl2pkcs7 -nocrl -certfile domain.crt -certfile ca-chain.crt -out domain.p7b

PKCS7 to PEM

- openssl pkcs7 -in domain.p7b -print_certs -out domain.crt

PEM to PKCS12

- openssl pkcs12 -inkey domain.key -in domain.crt -export -out domain.pfx

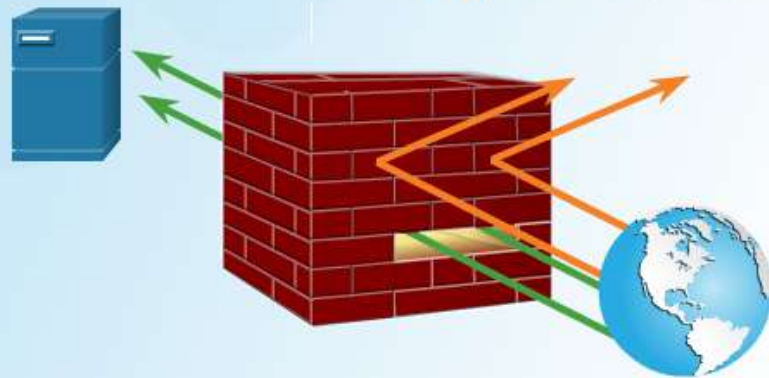
PKCS12 to PEM

- openssl pkcs12 -in domain.pfx -nodes -out domain.combined.crt

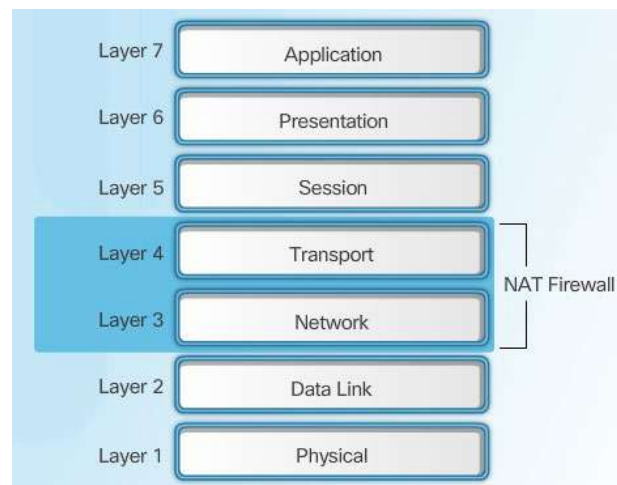
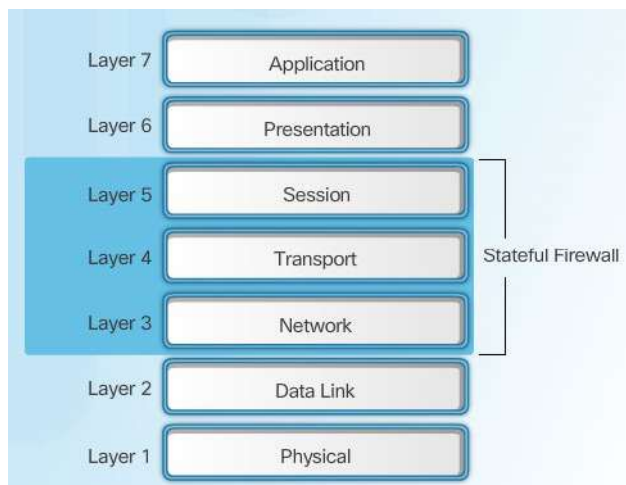
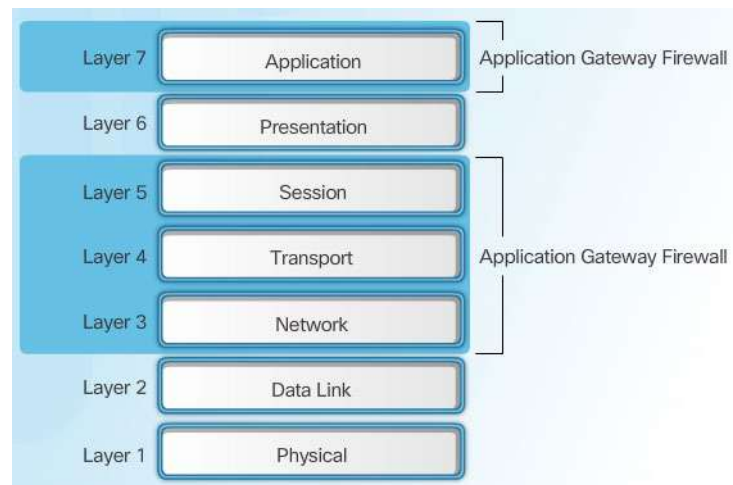
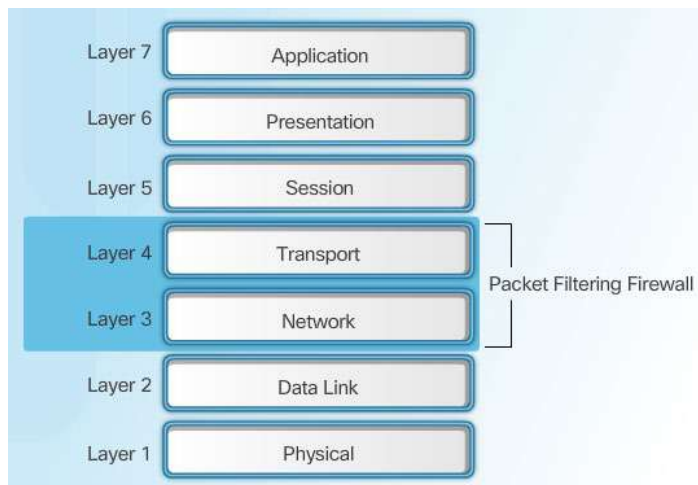
FIREWALL

Firewall

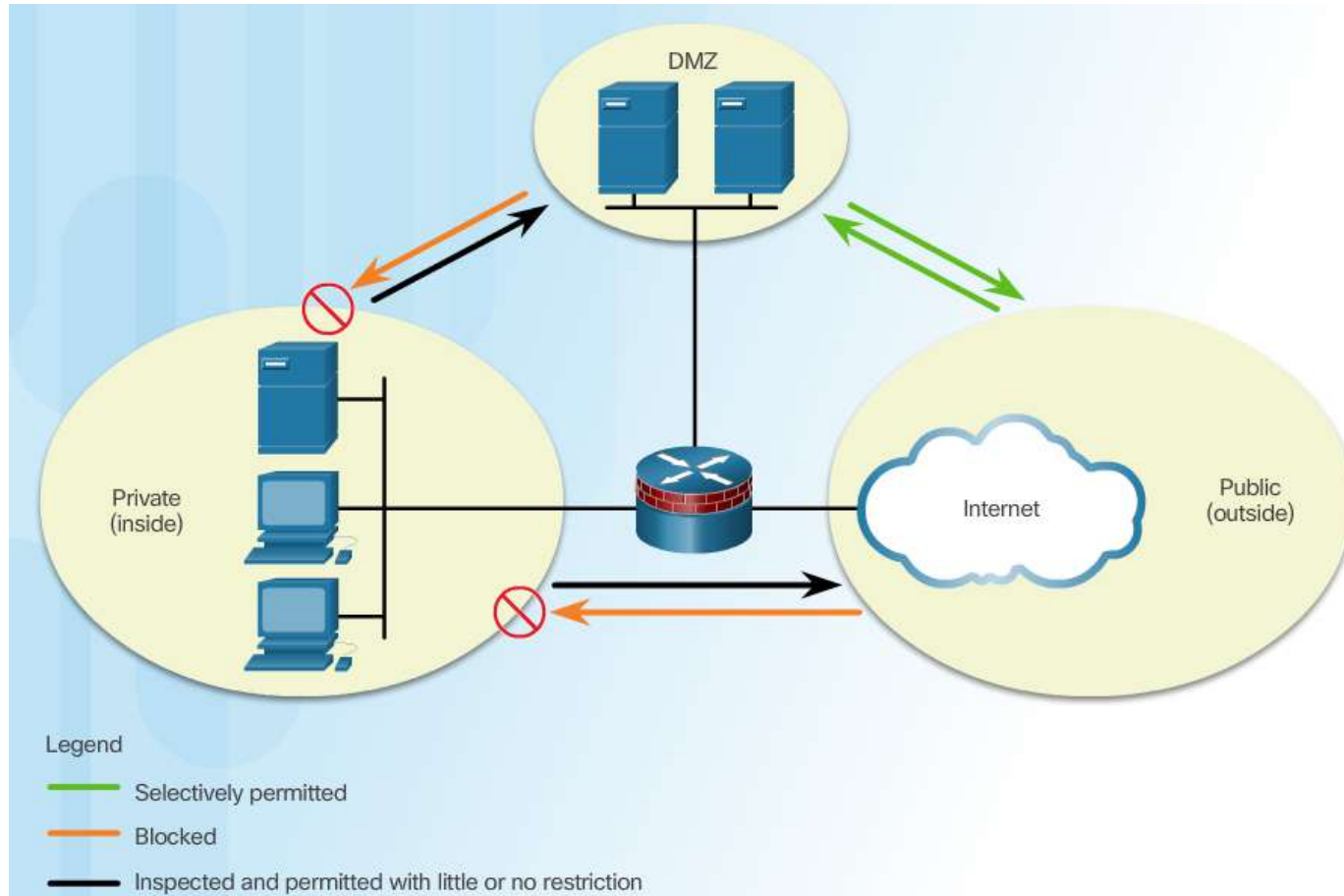
- **Allow** traffic from any external address to the web server.
- **Allow** traffic to FTP server.
- **Allow** traffic to SMTP server.
- **Allow** traffic to internal IMAP server.
- **Deny** all inbound traffic with network addresses matching internal-registered IP addresses.
- **Deny** all inbound traffic to server from external addresses.
- **Deny** all inbound ICMP echo request traffic.
- **Deny** all inbound MS Active Directory.
- **Deny** all inbound MS SQL server ports.
- **Deny** all MS Domain Local Broadcasts.



Typy firewallu



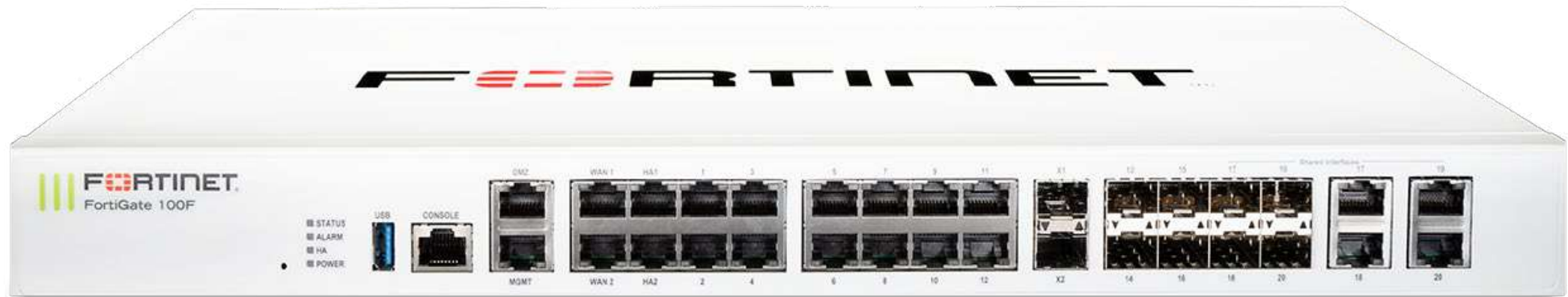
Firewall



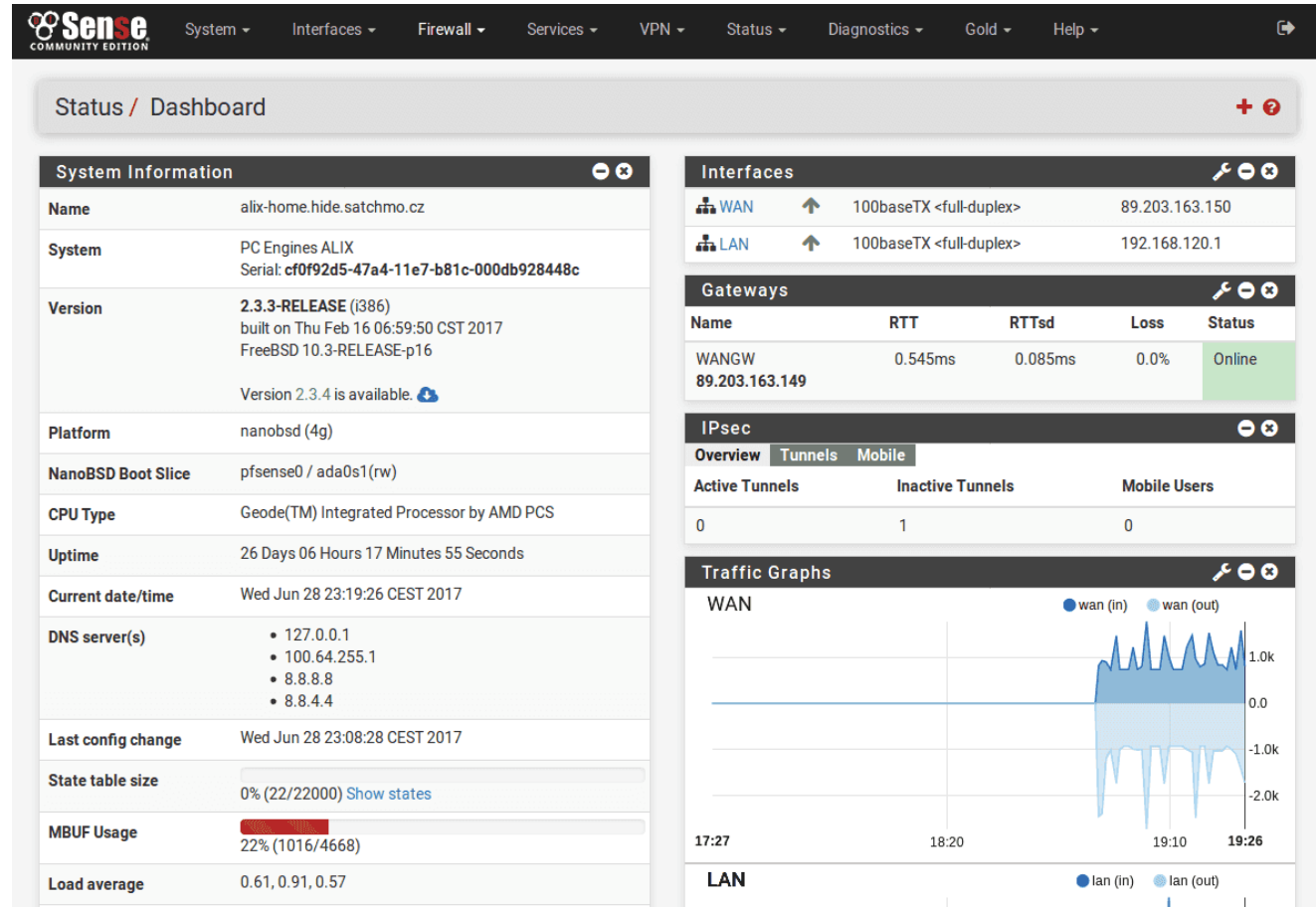
Cisco ASA



Fortigate



pfSense

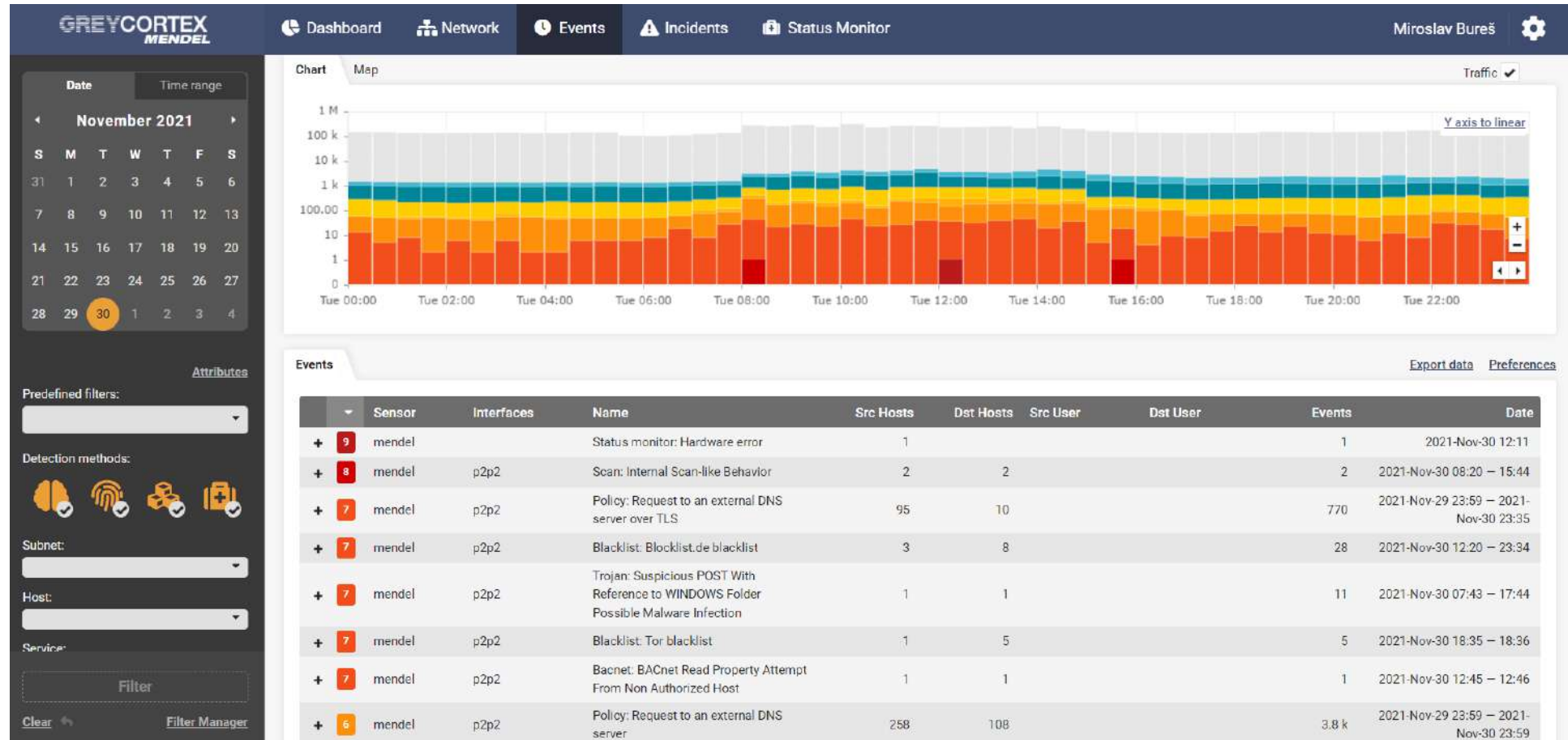


Vulnerability management

- Nmap
- Greenbone Security Manager (GSM)

IPS/IDS systémy

GrayCortex Mendel



Snort

```
Preprocessor Object: SF_SDF Version 1.1 <Build 1>
Preprocessor Object: SF_DNP3 Version 1.1 <Build 1>
Commencing packet processing (pid=20037)
08/27-21:37:34.850356  [**] [1:1420:11] SNMP trap tcp [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.1.23:64399 -> 192.168.1.25:162
08/27-21:37:35.465875  [**] [1:1421:11] SNMP AgentX/tcp request [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.1.23:64399 -> 192.168.1.25:705
08/27-21:37:35.841650  [**] [1:249:8] DDOS mstream client to handler [**] [Classification: Attempted Denial of Service] [Priority: 2] {TCP} 192.168.1.23:64399 -> 192.168.1.25:15104
08/27-21:37:36.806899  [**] [1:1418:11] SNMP request tcp [**] [Classification: Attempted Information Leak] [Priority: 2] {TCP} 192.168.1.23:64399 -> 192.168.1.25:161
08/27-21:37:37.808042  [**] [1:365:8] ICMP PING undefined code [**] [Classification: Misc activity] [Priority: 3] {ICMP} 192.168.1.23 -> 192.168.1.25
08/27-21:37:37.808067  [**] [1:409:7] ICMP Echo Reply undefined code [**] [Classification: Misc activity] [Priority: 3] {ICMP} 192.168.1.25 -> 192.168.1.23
```


Suricata



PROSTOR PRO VAŠE DOTAZY

DĚKUJI VÁM ZA POZORNOST